

LITERATURE SURVEY ON VULNERABILITY ASSESSMENT AND PENETRATION TESTING

OCTOBER 2025

AUTHORS : P.B.ROHIT , Amana Fathima , Arjun.S

ABSTRACT	4
KEYWORDS	5
INTRODUCTION	5
LITERATURE REVIEW	6
CYBERATTACK LIFE CYCLE	10
VAPT PROCESS(DEFENDER's VIEW)	11
VARIOUS ENVIRONMENT FOR CONDUCTING VAPT	11
HOW TO IMPLEMENT VAPT IN VARIOUS ENVIRONMENTS	12
SIMILARITIES AND DIFFERENCES ACROSS VARIOUS ENVIRONMENTS	12
CONCLUSION	13
REFERENCES	14
PHASE 2 –	15
RECONNAISSANCE / DISCOVERY REPORT	15
1. Engagement Overview	16
Tools & Techniques Used:	16
2. Passive Reconnaissance	16
Methodology	16
Findings	17
3. Active Reconnaissance & Directory Enumeration	17
Methodology	17
Timeline of Activities	17
Service & Software Fingerprinting	18
Directory and Endpoint Discovery	18
Detailed Active Scan Results	19
4. Source Code Enumeration	22
5. Risk Identification & Prioritization	23
6. Security Posture Commentary	23
7. Recommendations	23
8. Appendices	24
1.Passive Reconnaissance	24
a. Whois	24
b. Apache2 Ubuntu Default page	26
c.phpMyAdmin Login Panel (/phpmyadmin/):	26
d.server-status (139.59.2.14):	27
e.ipinfo	27
f. AbuseIPDB	28
g.Shodan	29
h. Dig	29
i.Censys	30

2. Active Reconnaissance	33
a. Ping	33
b. Nmap	34
c. Gobuster	35
d. Curl	35
9. References	36
10. Review Checklist	36
11. Contribution	36
12. Conclusion	37
PHASE 3 -	38
VULNERABILITY ASSESSMENT	38
Vulnerability Assessment Report	39
1. Executive Summary	39
2. Methodology	39
· Frameworks Applied:	39
· Testing Tools and Procedures:	39
3. Vulnerability Summary Report	40
4. Detailed Vulnerability Registry	41
5. Risk Assessment	42
• Remote Code Execution & Privilege Escalation:	42
• Authentication Bypass & Session Hijacking:	42
• Denial of Service Attacks:	43
• Sensitive Data Exposure:	43
• Regulatory & Reputational Impact:	43
Risk Severity:	43
6. Recommendations	44
Immediate Actions (Critical Response):	44
7. Appendices	45
1. gobuster	45
2. nikto	45
3. Openvas & nuclei	46
4. Nessus	47
Preventive & Long-term Actions:	50
Regulatory Compliance & Awareness:	50
8. Contribution	51
9. Conclusion	51
10. References	52

Phase 4 -	53
PENETRATION TESTING PHASE	53
1. Engagement Overview	54
2. Executive Summary	54
3. Methodology and Exploitation Strategy	54
4. Detailed Exploitation Scenarios	54
5. Highest Level of Access & Business Impact	55
6. Appendix	56
7. Remediation Table	62
Priority Order:	63
8.Recommendation	63
9. Contribution	65
10. Conclusion	66

ABSTRACT

Information security is often neglected by the individual or the employee or even by the enterprise, while there is no proper strategy to raise awareness, promote consistency, and maintain performance regarding protecting sensitive, confidential, and critical data. All Internet-facing systems and applications carry security risks. These security risks are addressed by the cyber security professionals using Vulnerability Assessment and Penetration Testing Tools and Techniques. The VAPT is an offensive way of defending the cyber assets of an organization. It consists of two major parts: Vulnerability Assessment(VA) and Penetration Testing(PT). Vulnerability Assessment includes the use of various automated tools and manual techniques to determine the security posture of the target system. In this step all the breaches and loopholes are found. These breaches/loopholes found by an attacker can lead to heavy data loss and fraudulent intrusion activities. In penetration testing, the tester simulates the activities of a malicious attacker who tries to exploit the vulnerabilities of the target system. In this step, the identified set of vulnerabilities is used as the input vector. The process of VAPT helps in assessing the effectiveness of the security measures that are present on the target system. In this report, I have described the cyberattack lifecycle, and how VAPT differs from the cyberattack lifecycle. A list of different environments where it can be performed and how it can be performed and implemented in various environments. The similarities and differences between the environments are also provided with some examples, case studies, and references.

KEYWORDS

Vulnerability Assessment, Penetration Testing, Cyberattack Lifecycle, Vulnerabilities, Tools and Techniques

INTRODUCTION

Vulnerability Assessment and Penetration techniques are essential practices in cybersecurity to identify, and fix, the security flaws in devices, applications, and networks. With the increase in cyberattacks, Organizations require a structured approach to secure their infrastructure. VAPT consists of Two complementary techniques:

1. **Vulnerability Assessment** - It focuses on identifying and classifying vulnerabilities. It uses automated tools and manual techniques to find out the vulnerabilities. It will identify security gaps such as misconfigured systems, outdated software patches, insecure APIs, and weak access controls. It will also give a report on the type of vulnerabilities and their severity.
2. **Penetration Testing** - It exploits vulnerabilities to assess risks. This is an active process where ethical hackers attempt to exploit the vulnerability identified during the VA phase. It simulates a real cyber attack how the attacker could weaponize the weaknesses and the potential business consequences. It helps in understanding the effectiveness of security controls and identifies weaknesses that may be hidden from automated scans.

LITERATURE REVIEW

1. SCARFONE AND MELL (2007)

It provided foundational guidelines for conducting vulnerability assessments and penetration testing(VAPT). Their work published in 2007 gave a structured methodology for planning, executing, and documenting security testing. This framework distinguishes between vulnerability assessment and penetration testing.

Key Contributions include:

- Defining standardized terminology for VAPT activities.
- Introduced a phased methodology - Planning, Discovery, Attack, and Reporting.
- Emphasized the importance of scope, rules of engagement, and documentation.
- It also highlighted ethical and legal considerations in security testing.

Limitations/Gaps:

- It focussed largely on Traditional It systems (networks, servers, and applications)
- Less coverage on modern environments like IoT, cloud, and AI-driven systems.
- The tools and vectors are outdated , as it was published in 2007

2. MANSFIELD-DEVINE(2016)

It examined the growing importance of penetration testing in cybersecurity.This article showed how penetration testing became a core component of organizational secure strategies, driven by the increased complexity of threats and regulatory processes.

Contributions:

- It showed how regulations, compliance, and industry standards pushed penetration testing into mainstream cybersecurity.

- It emphasized the role of ethical hackers and external testing teams in uncovering vulnerabilities missed by automated tools.
- It discussed the importance of stimulated real-world attacks to validate security measures, rather than relying solely on vulnerability scanners.
- Pointed out the importance of the organizations turning to red team/blue team to test resilience.

Limitations/Gaps:

- This is more of a practical and descriptive article rather than a formal methodological framework.
- Focused heavily on IT environments, with limited coverage into areas such as IOT and cloud based systems.

3. Ali.S (2022)

It examined the modern security challenges in web applications and how penetration testing can aid and address the challenges. The study examines common web based vulnerabilities - such as SQL injection, cross-site scripting, Broken Authentication and others which come under OWASP top 10 vulnerabilities. The authors adopt OWASP testing methodology which includes phases like information gathering, configuration and deployment management testing, authentication testing, session management testing, input validation testing, and business logic testing.

Contributions:

- Clear Mapping between OWASP top ten vulnerabilities and Penetration methods.
- Offers Practical testing strategies with examples

- Stresses iterative and continuous penetration testing, rather than one time engagements.

Limitations/Gaps:

- Primarily focuses on web-driven based applications
- Limited discussion on automation and AI-based PT tools

4. CONTI.M (2018)

This study examined the growing cybersecurity risks associated with Internet of Things and Devices and discusses how VAPT can be adapted to this environment.

It also emphasized the importance of lightweight security testing methods that respect the limited computational resources of IOT devices.

In this study, the authors have used approaches such as Firmware analysis, Network traffic monitoring for insecure testing, Physical Interface testing, Penetration Testing adopted for heterogeneous IOT ecosystems.

Contributions:

- Comprehensive mapping between IOT vulnerabilities and corresponding VAPT methods
- Highlights both technical and practical considerations
- Bridges the gap between general cybersecurity frameworks and specific needs of IOT systems.

Limitations/Gaps:

- Focuses more on known vulnerabilities, less importance on Zero-day detection and advanced AI detection.
- The discussion remains largely conceptual, with fewer case studies.

5. SHAH AND MEHTA (2020)

This study presented a VAPT methodology specifically tailored for cloud environments, addressing challenges like multi tenancy, Virtualization, and Dynamic Scaling. This study is able to prove that the cloud infrastructure differs primarily from on-premises IT systems.

Contributions:

- Proposed a cloud specific VAPT framework, integrating traditional pentesting phases with cloud security
- Emphasized Virtualisation, Containerization, and API security as the critical assessment points.
- Discussed multi-tenancy risks and the shared responsibility model in cloud security.
- Highlighted the use of automated tools and manual verification for higher accuracy.
- Provided a comparative analysis of public,private, and hybrid clouds in terms of VAPT.

Limitations/Gaps:

- Framework was conceptual with limited empirical validation
- Focussed primarily on Iaas and Paas models, giving less attention to SaaS.

CYBERATTACK LIFE CYCLE

The Cyberattack Life Cycle(Cyber Kill chain) describes the step by step process attackers follow to compromise systems, maintain access, and achieve their goals. It helps defenders understand how attacks can happen, and where to apply countermeasures.

Stages of CyberAttack Life Cycle are:

1. Reconnaissance(Information Gathering) - Gathers information about the target(IP addresses, domain names, employees, open ports, technologies used). Tools such as Google Dorking, whois, social engineering, nmap.
2. Weaponization - The attacker prepares an exploit or a malicious payload according to the vulnerabilities found. Example: Crafting Malware
3. Delivery - The malicious payload is sent to the target. Examples: E-mail attachments, Malicious Links, etc
4. Vulnerability - Vulnerability is exploited to execute the attack code. Examples- An unpatched system, Executing a web application flaw.

5. Installation - Malware/Backdoor/Rootkit is installed to gain persistent access. Example - Dropping a remote access Trojan
6. Command and Control(C2) - The compromised system connects back to the attackers infrastructure. Attackers can now remotely connect the system.
7. Actions on Objectives(Impact/Exfiltration) - Data Theft, System Damage, Espionage, Disruption.

VAPT PROCESS(DEFENDER's VIEW)

1. INFORMATION GATHERING - Identify scope, assets, and collect data about the target environment.
2. Vulnerability Assessment - Using tools and scanners to identify vulnerabilities but without creating real payloads.
3. Penetration Testing - Exploitation Attempt - Simulate delivery channels in a controlled manner.
4. Exploitation(controlled) - Test if vulnerabilities be actually exploited, but stop before causing damage.
5. Post-Exploitation - Demonstrate possible persistence techniques but avoiding destructive actions
6. Reporting - Instead of setting up C2, testers document how it could be done and recommend fixes.
7. Remediation and Re-Testing - Deliver findings, help patch vulnerabilities, and verify fixes to prevent real attackers from succeeding.

VARIOUS ENVIRONMENT FOR CONDUCTING VAPT

1. Web Applications and API's - Public websites, SPA's
2. Network Infrastructure - Internal/External Network, Firewall, Routers, and Switches.
3. Cloud Infrastructure - Iaas, Paas, Saas
4. Mobile Apps - Android/iOS

5. IoT Devices - Firmware, radio protocols, local web interfaces

HOW TO IMPLEMENT VAPT IN VARIOUS ENVIRONMENTS

1. Web Applications and API's

- Pre-engagement - Include test accounts, test data rules, CSRF protections, DoS constraints.
- Recon - Enumerate sub-domains, public endpoints, and API docs
- Assessment Tools - Burpsuite, Nikto
- Manual focus - Auth flaws, Business logic, Access Control, Injection.

2. Network Infrastructure

- Pre-engagement - Get Network Diagrams, Schedule maintenance windows for intrusion tests.
- Recon - External Mapping(nmap), Internal discovery(Netbios, SMB enumeration)
- Assessment tools - Nessus,nmap, Metasploit for exploitation
- Manual focus - Misconfigurations, Weak Credentials, Exposed Management Interfaces.

3. Cloud Interfaces (AWS/AZURE/GCP)

- Scope carefully - Determine provider policies and scope(customer oriented and provider)
- Focus areas - IAM misconfigurations, exposed buckets, metadata API access, misconfigured roles.
- Tools - Cloud provider CLIs, Scoutsuite, Prowler

4. IOT Devices

- Unique Constraints - Firmware analysis, Hardware interfaces, Radio protocols, Limited Update mechanisms. Physical Access might be required.
- Approach - Firmware static analysis, dynamic testing on device etc..

SIMILARITIES AND DIFFERENCES ACROSS VARIOUS ENVIRONMENTS

SIMILARITIES

- All follow the same high level process: scope, recon, detect, exploit/verify, report, retest
- Need for legal approvals, asset classification and prioritization, and remediation tracking.

DIFFERENCES

1. Reconnaissance

- Web - More emphasis is given on public enumeration, and detecting endpoints.
- IOT - Includes hardware discovery and physical probing
- Cloud - Includes probing IAM/METADATA

2. Vulnerability Assessment

- Web and Network - Automated scanning gives more yield
- IOT - Automated scanning gives less yield, much more manual, thorough understanding of protocol is needed

3. Exploitation phase

- Web and Network - Performs Non destructive exploits in most cases.
- IOT - Exploitation can cause physical harm and can even lead to damage of devices.

4. Authentication

- Cloud - IAM misconfigurations are a primary vector.
- Web Apps - Session management, broken auth are more relevant

CONCLUSION

In reviewing the existing literature on VAPT, it becomes clear that VAPT has a key component of cybersecurity strategy. Researchers and professionals emphasize the role of VAPT in identifying security flaws and loopholes across diverse environments ranging from networks, web applications, cloud, and IoT. While traditional testing relies mainly on manual tools and techniques, there is a growing trend of continuous automation, machine learning integration to address the scale of complexity of modern infrastructures.

Despite advancements, there are still gaps found, mainly in detecting zero day vulnerabilities and managing false positives. The lack of frameworks and standards across different industries reduces the comparability of results.

Further research should be required for a creative, adaptive, and standardized methodologies that goes with the nature of cyber threat. Furthermore integrating real time analysis capabilities, and extending testing to AI driven technologies and critical IOT systems represent positive directions.

In conclusion, VAPT remains indispensable for maintaining organizational resilience in the face of evolving cyber threats. A Unified effort is required for Standardization in this field, which will bridge the gaps among the diverse fields and ensure VAPT continues to serve as a safeguard in the cybersecurity lifecycle.

REFERENCES

1. Scarfone, K., & Mell, P. (2007). *Guide to Penetration Testing and Vulnerability Assessment*. NIST.
2. Mansfield-Devine, S. (2016). *The Cyber Attack Lifecycle and its Relation to Penetration Testing*. Network Security.
3. Ali, S., et al. (2022). *Penetration Testing of Web Applications: Challenges and Methods*. OWASP Journal.
4. Conti, M., et al. (2018). *Cybersecurity of IoT Devices: A VAPT Perspective*. ACM Computing Surveys.

5. Shah, D., & Mehta, R. (2020). *VAPT Methodology for Cloud Environments*. *IEEE Access*.
6. <https://www.redseclabs.com/blog/vulnerability-assessment-vs-penetration-testing-key-differences-and-why-they-matter/>
7. <https://owasp.org/www-project-web-security-testing-guide/>
8. <https://www.mdpi.com/2076-3417/13/12/>
9. <https://www.guidepointsecurity.com/education-center/cloud-penetration-testing/>
10. <https://kratikal.com/blog/best-practices-and-challenges-in-iot-testing/>
11. <https://github.com/OWASP/wstg/tree/master/document>

**PHASE 2 –
RECONNAISSANCE / DISCOVERY
REPORT**

1. Engagement Overview

- **Project Name:** Reconnaissance of 139.59.2.14
- **Client / Organization:** ICTAK
- **Date of Reconnaissance:** 06-10-2025 to 09-10-2025
- **Test Team / Tester:** P.B Rohit , Amana Fathima , Arjun Sunil
- **Target Scope of Reconnaissance:** Public-facing IP (139.59.2.14): Only HTTP services, endpoints, directories, banners, and headers; no vulnerability checks or exploitation performed.

Tools & Techniques Used:

- Chrome/Firefox/Edge (Browser-based review)
- Nmap v7.95 (Network, OS, Service Discovery)
- Gobuster v3.6 (Directory brute-force)
- CURL (Header analysis)
- OSINT tools: WHOIS, ipinfo.io, Shodan

2. Passive Reconnaissance

Methodology

- WHOIS, Shodan, ipinfo.io, AbuseIPDB, Censys (public data only)
- Search engine queries (Google, Bing)
- PTR and ASN
- Check for blacklists, cloud geolocation, open-source mentions

Findings

- **IP:** 139.59.2.14
- **Provider:** DigitalOcean LLC (ASN14061), Bengaluru, India
- **Reverse DNS (PTR):** Not set
- **Blacklist Status / Threat Reputation:** No active or historical threats; asset is clean

- **Indexed Content:** None found (Google/Bing)
- **Mentions in Public Feeds & Forums:** None
- **Usage Profile:** Cloud asset suggests test/dev deployment

3. Active Reconnaissance & Directory Enumeration

Methodology

- Direct, minimal engagement to enumerate asset characteristics
- Tools: Browser, Nmap, Gobuster, CURL

Timeline of Activities

Step	Timestamp	Tool/Method
Passive OSINT	08 Oct 2025, 11:00	WHOIS, Shodan
Passive asset search	08 Oct 2025, 11:00	<u>ipinfo.io</u> , Censys
Passive web search	08 Oct 2025, 11:05	Google, Bing
Manual endpoint review	08 Oct 2025, 11:10	Browser
Full port scan	08 Oct 2025, 11:15	Nmap
Directory brute-force	08 Oct 2025, 11:20	Gobuster
Header analysis/screens	08 Oct 2025, 11:30	cURL, Browser

Service & Software Fingerprinting

- **Server Banner:** Apache/2.4.41 (Ubuntu)
- **Operating System:** Ubuntu Linux
- **Security Headers:** None (no HSTS or X-Frame-Options present)

Directory and Endpoint Discovery

Endpoint	Status	Comments
/	200 OK	Default Apache (uncustomized)
/phpmyadmin/	200 OK	Public login panel exposed
/robots.txt	404 Not Found	Not present
/info.php	404 Not Found	Not present
/server-status	403 Forbidden	Feature present, forbidden
/uploads/	404 Not Found	Not present

Detailed Active Scan Results

nmap

sudo nmap -A 139.59.2.14

[sudo] password for rohit:

Starting Nmap 7.95 (<https://nmap.org>) at 2025-10-09 13:02 IST

Nmap scan report for 139.59.2.14

Host is up (0.041s latency).

Not shown: 987 closed tcp ports (reset)

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

21/tcp	open	ftp	OpenBSD ftpd 6.4 (Linux port 0.17)
--------	------	-----	------------------------------------

22/tcp	open	ssh	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
--------	------	-----	---

| ssh-hostkey:

| 3072 f0:5f:7b:6d:90:42:92:00:4a:e0:2b:02:0e:f6:74:bc (RSA)

| 256 92:ce:8f:ef:f0:96:bd:dc:89:7a:b1:b7:0c:b0:e5:db (ECDSA)

|_ 256 f7:29:e3:d5:cb:9d:63:ae:08:1f:32:ed:55:b0:10:19 (ED25519)

25/tcp	filtered	smtp	
--------	----------	------	--

53/tcp	open	domain	ISC BIND 9.18.30-0ubuntu0.20.04.2 (Ubuntu Linux)
--------	------	--------	--

| dns-nsid:

|_ bind.version: 9.18.30-0ubuntu0.20.04.2-Ubuntu

80/tcp	open	http	Apache httpd 2.4.41 ((Ubuntu))
--------	------	------	--------------------------------

|_http-server-header: Apache/2.4.41 (Ubuntu)

|_http-title: Apache2 Ubuntu Default Page: It works

111/tcp	open	rpcbind	2-4 (RPC #100000)
---------	------	---------	-------------------

| rpcinfo:

| program version port/proto service

| 100000 2,3,4 111/tcp rpcbind

| 100000 2,3,4 111/udp rpcbind

| 100000 3,4 111/tcp6 rpcbind

| 100000 3,4 111/udp6 rpcbind

| 100003 3 2049/udp nfs

| 100003 3 2049/udp6 nfs

| 100003 3,4 2049/tcp nfs

| 100003 3,4 2049/tcp6 nfs

| 100005 1,2,3 34386/udp mountd

| 100005 1,2,3 38478/udp6 mountd

| 100005 1,2,3 53471/tcp6 mountd

| 100005 1,2,3 55039/tcp mountd

| 100021 1,3,4 38757/tcp6 nlockmgr

| 100021 1,3,4 41661/tcp nlockmgr

| 100021 1,3,4 43103/udp6 nlockmgr

| 100021 1,3,4 56736/udp nlockmgr

| 100227 3 2049/tcp nfs_acl

| 100227 3 2049/tcp6 nfs_acl

| 100227 3 2049/udp nfs_acl

|_ 100227 3 2049/udp6 nfs_acl

135/tcp filtered msrpc

139/tcp filtered netbios-ssn

389/tcp open ldap OpenLDAP 2.2.X - 2.3.X

443/tcp open http-proxy (bad gateway)

|_http-title: Site doesn't have a title (text/html; charset="UTF-8").

| fingerprint-strings:

| GetRequest:

| HTTP/1.1 502 Connection refused

| Date: Thu, 09 Oct 2025 07:32:16 GMT

| Cache-Control: no-cache

| Pragma: no-cache

| Content-Type: text/html; charset="UTF-8"

| Content-Length: 74231

| Via: HTTP/1.1 forward.http.proxy:3128

| Connection: close

| <!doctype html>

| <html>

| <head>

| <meta charset='utf-8'>

| <title></title><style type='text/css'> @charset 'utf-8';

| html, body { height: 100%; margin: 0; }

| body { font-family: 'Helvetica Neue','Helvetica','Segoe UI', Arial, sans-serif;
 color:#5c5c5c; background: #fafafa}

| text-decoration: none; color: #169ad5; }

| a:focus { outline: none; }

| a:hover { color:

445/tcp filtered microsoft-ds

2049/tcp open nfs 3-4 (RPC #100003)

7007/tcp filtered afs3-bos

- **Gobuster Directory Scan:**

- **Command:** `gobuster dir -u http://139.59.2.14 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt`

- **Output:**

- § `/phpmyadmin` [Status: 200] – Public login panel

- § `/server-status` [Status: 403] – Feature present, access forbidden

- § `/` [Status: 200] – Apache welcome page

- **CURL Header Analysis:**

- **Command:** `curl -I http://139.59.2.14/`

- **Output:**

- § **Server:** Apache/2.4.41 (Ubuntu)

- § **Content-Type:** text/html

Observations & Attack Vectors

- Publicly exposed phpMyAdmin panel
- Default Apache2 test page (Debian branding visible)
- `/server-status` endpoint is present, forbidden from public access
- No HTTPS or advanced headers; session/data security risk
- Default/test configuration indicative of fresh or neglected instance
- An ETag is present (2aa6-5e3c7fdbe936f) ETag is an HTTP header used for web cache validation and resource versioning.

4. Source Code Enumeration

- **Issue:** Debian-branded Apache default page appearing on Ubuntu
- **Impact:** Cosmetic/packaging bug only (see Launchpad Bug #1288690)
- **Security Impact:** None, unless used for social engineering/confusion

5. Risk Identification & Prioritization

Issue	Severity	Recommendation
phpMyAdmin Exposed	High	Restrict/remove, enforce strong authentication
No HTTPS	Medium	Enable HTTPS, use valid certificate
Default Config	Low	Harden Apache2, remove defaults
No WAF/Rate-limit	Medium	Add WAF/rate limiting

6. Security Posture Commentary

The system displays typical signs of an uncustomized, potentially neglected web instance. Public-facing admin tools, lack of secure headers, and default landing content all represent substantial risks, particularly to unsupervised test/dev or production deployments.

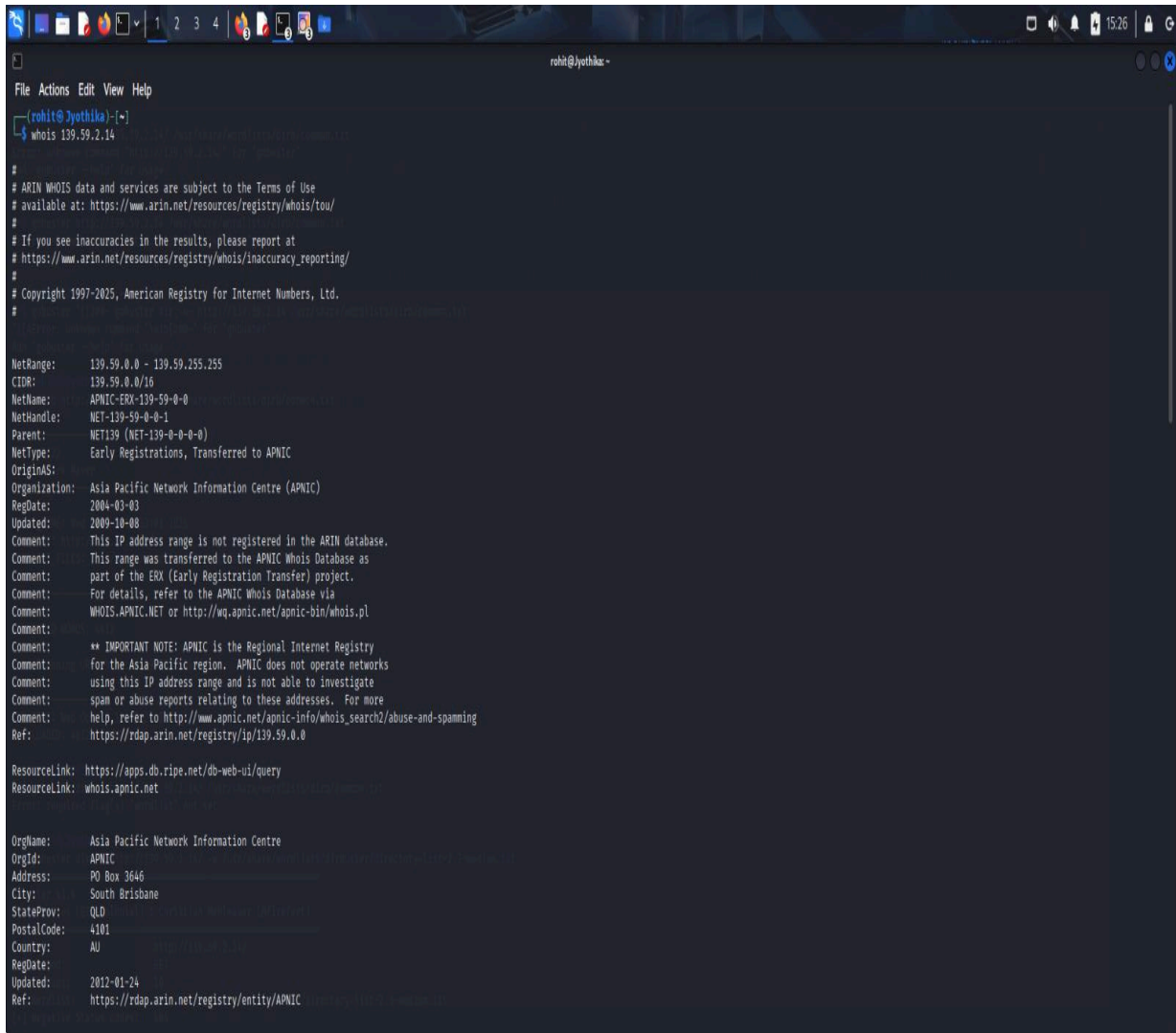
7. Recommendations

- Firewall, restrict, or disable public access to /phpmyadmin/ panel immediately
- Enforce HTTPS with valid certificates
- Harden Apache configurations, eliminate default/test pages
- Restrict /server-status or disable if not necessary
- Update cloud firewall settings, rotate credentials
- Train technical staff on basic web server security

8. Appendices

1.Passive Reconnaissance

a. Whois

A screenshot of a terminal window titled 'rohit@jyothika: ~'. The terminal shows the command 'whois 139.59.2.14' and its output. The output includes ARIN WHOIS data, APNIC details for the 139.59.0.0/16 range, and contact information for APNIC. The terminal has a dark background with light-colored text. The window's title bar shows standard Linux window controls and the system clock at 15:26.

```
rohit@jyothika: ~  
$ whois 139.59.2.14  
  
#  
# ARIN WHOIS data and services are subject to the Terms of Use  
# available at: https://www.arin.net/resources/registry/whois/tou/  
#  
# If you see inaccuracies in the results, please report at  
# https://www.arin.net/resources/registry/whois/inaccuracy\_reporting/  
#  
# Copyright 1997-2025, American Registry for Internet Numbers, Ltd.  
#  
  
NetRange: 139.59.0.0 - 139.59.255.255  
CIDR: 139.59.0.0/16  
NetName: APNIC-ERX-139-59-0-0  
NetHandle: NET-139-59-0-0-1  
Parent: NET139 (NET-139-0-0-0-0)  
NetType: Early Registrations, Transferred to APNIC  
OriginAS:  
Organization: Asia Pacific Network Information Centre (APNIC)  
RegDate: 2004-03-03  
Updated: 2009-10-08  
Comment: This IP address range is not registered in the ARIN database.  
Comment: This range was transferred to the APNIC Whois Database as  
Comment: part of the ERX (Early Registration Transfer) project.  
Comment: For details, refer to the APNIC Whois Database via  
Comment: WHOIS.APNIC.NET or http://wq.apnic.net/apnic-bin/whois.pl  
Comment:  
Comment: ** IMPORTANT NOTE: APNIC is the Regional Internet Registry  
Comment: for the Asia Pacific region. APNIC does not operate networks  
Comment: using this IP address range and is not able to investigate  
Comment: spam or abuse reports relating to these addresses. For more  
Comment: help, refer to http://www.apnic.net/apnic-info/whois\_search2/abuse-and-spamming  
Ref: https://rdap.arin.net/registry/ip/139.59.0.0  
  
ResourceLink: https://apps.db.ripe.net/db-web-ui/query  
ResourceLink: whois.apnic.net  
  
OrgName: Asia Pacific Network Information Centre  
OrgId: APNIC  
Address: PO Box 3646  
City: South Brisbane  
StateProv: QLD  
PostalCode: 4101  
Country: AU  
RegDate:  
Updated: 2012-01-24  
Ref: https://rdap.arin.net/registry/entity/APNIC
```

```
File Actions Edit View Help
Comment:      spam or abuse reports relating to these addresses. For more
Comment:      info, refer to http://www.apnic.net/apnic-info/whois\_search2/abuse-and-spamming
Ref:          https://rdap.arin.net/registry/ip/199.59.0.0
ResourceLink: https://apps.db.ripe.net/db-web-ui/query
ResourceLink: whois.apnic.net

OrgName:      Asia Pacific Network Information Centre
OrgId:        APNIC
Address:      90 Box 3646
City:         South Brisbane
StateProv:    QLD
PostalCode:   4101
Country:      AU
RegDate:      2012-01-24
Updated:      2022-01-24
Ref:          https://rdap.arin.net/registry/entity/APNIC
ReferralServer: whois://whois.apnic.net
ResourceLink: https://apps.db.ripe.net/db-web-ui/query
OrgAbuseHandle: AWC12-ARIN
OrgAbuseName:  APNIC Whois Contact
OrgAbusePhone: +61 7 3858 3188
OrgAbuseEmail: search-apnic-not-arin@apnic.net
OrgAbuseRef:   https://rdap.arin.net/registry/entity/AWC12-ARIN
OrgTechHandle: AWC12-ARIN
OrgTechName:   APNIC Whois Contact
OrgTechPhone:  +61 7 3858 3188
OrgTechEmail:  search-apnic-not-arin@apnic.net
OrgTechRef:    https://rdap.arin.net/registry/entity/AWC12-ARIN

# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy\_reporting/
#
# Copyright 1997-2025, American Registry for Internet Numbers, Ltd.
#

Found a referral to whois.apnic.net.

% [whois.apnic.net]
% Whois data copyright terms    http://www.apnic.net/db/dbcopyright.html
```

```
File Actions Edit View Help
mnt-irt:      IRT-DIGITALOCEAN-AP
last-modified: 2020-05-31T21:32:24Z
source:       APNIC

irt:          IRT-DIGITALOCEAN-AP
address:      185 Edgeview Drive, Suite 425, Broomfield, Colorado 80021
e-mail:       noc@digitalocean.com
abuse-mailbox: abuse@digitalocean.com
admin-c:      DOIA2-AP
tech-c:       DOIA2-AP
auth:         # Filtered
remarks:      noc@digitalocean.com was validated on 2015-05-20
remarks:      abuse@digitalocean.com was validated on 2025-08-14
mnt-by:       MAINT-DIGITALOCEAN-AP
last-modified: 2025-09-04T07:01:35Z
source:       APNIC

role:         ABUSE DIGITALOCEANAP
country:      ZZ
address:      185 Edgeview Drive, Suite 425, Broomfield, Colorado 80021
phone:        +8888888888
e-mail:       noc@digitalocean.com
admin-c:      DOIA2-AP
tech-c:       DOIA2-AP
nic-hdl:      AD699-AP
remarks:      Generated from irt object IRT-DIGITALOCEAN-AP
remarks:      noc@digitalocean.com was validated on 2015-05-20
remarks:      abuse@digitalocean.com was validated on 2025-08-14
abuse-mailbox: abuse@digitalocean.com
mnt-by:       APNIC-ABUSE
last-modified: 2025-08-14T13:27:09Z
source:       APNIC

role:         Digital Ocean Inc administrator
address:      185 Edgeview Drive, Suite 425, Broomfield, Colorado 80021
country:      US
phone:        +1 646-827-4366
fax-no:       +1 646-827-4366
e-mail:       abuse@digitalocean.com
admin-c:      DOIA2-AP
tech-c:       DOIA2-AP
nic-hdl:      DOIA2-AP
mnt-by:       MAINT-DIGITALOCEAN-AP
last-modified: 2025-08-11T16:24:27Z
source:       APNIC

% This query was served by the APNIC Whois Service version 1.88.36 (WHOIS-TP1)

(rohit@jyothika) ~
```

b. Apache2 Ubuntu Default page



Apache2 Ubuntu Default Page

It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Ubuntu systems. It is based on the equivalent page on Debian, from which the Ubuntu Apache packaging is derived. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

Ubuntu's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Ubuntu tools. The configuration system is **fully documented in `/usr/share/doc/apache2/README.Debian.gz`**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Ubuntu systems is as follows:

```
/etc/apache2/  
|-- apache2.conf  
|  
|   |-- ports.conf  
|-- mods-enabled  
|   |-- *.Load  
|   |-- *.conf  
|-- conf-enabled  
|   |-- *.conf  
|-- sites-enabled  
|   |-- *.conf
```

- `apache2.conf` is the main configuration file. It puts the pieces together by including all remaining configuration files when starting up the web server.
- `ports.conf` is always included from the main configuration file. It is used to determine the listening ports for incoming connections, and this file can be customized anytime.
- Configuration files in the `mods-enabled/`, `conf-enabled/` and `sites-enabled/` directories contain particular configuration snippets which manage modules, global configuration fragments, or virtual host configurations, respectively.
- They are activated by symlinking available configuration files from their respective `*-available/` counterparts. These should be managed by using our helpers `a2enmod`, `a2dismod`, `a2ensite`, `a2dissite`, and `a2enconf`, `a2disconf`. See their respective man pages for detailed information.
- The binary is called `apache2`. Due to the use of environment variables, in the default configuration, `apache2` needs to be started/stopped with `/etc/init.d/apache2` or `apache2ctl`. **Calling `/usr/bin/apache2` directly will not work** with the default configuration.

Document Roots

By default, Ubuntu does not allow access through the web browser to any file apart of those located in `/var/www/`, **public_html** directories (when enabled) and `/usr/share/` (for web applications). If your site is using a web document root located elsewhere (such as in `/srv/`) you may need to whitelist your document root directory in `/etc/apache2/apache2.conf`.

c.phpMyAdmin Login Panel (`/phpmyadmin/`):



Welcome to phpMyAdmin

Language

English

Log in

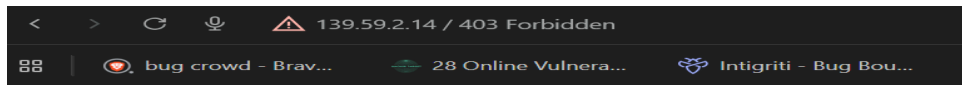
Username:

Password:

Go

Failed to set session cookie. Maybe you are using HTTP instead of HTTPS to access phpMyAdmin.

d.server-status (139.59.2.14):



Forbidden

You don't have permission to access this resource.

Apache/2.4.41 (Ubuntu) Server at 139.59.2.14 Port 80

e.ipinfo

IPinfo 139.59.2.14

All IP Ranges > 139.0.0.0/8 > 139.59.0.0/16 > 139.59.2.0/24 > 139.59.2.14

139.59.2.14

This IP has been flagged as abusive — see [AbuseIPDB](#) for details.

Báshettihalli, Karnataka, IN cloud hosting

Need more data or want to access it via API or data downloads? Sign up to get free access Sign up for free

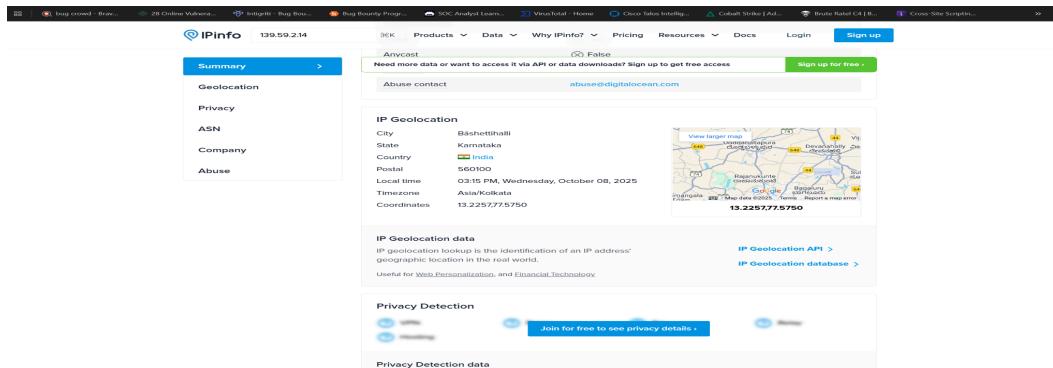
Summary

ASN	AS14061 - DigitalOcean, LLC
Hostname	No Hostname
Range	139.59.0.0/20
Company	DigitalOcean, LLC
Hosted domains	0
Privacy	True
Anycast	False
ASN type	Hosting
Abuse contact	abuse@digitalocean.com

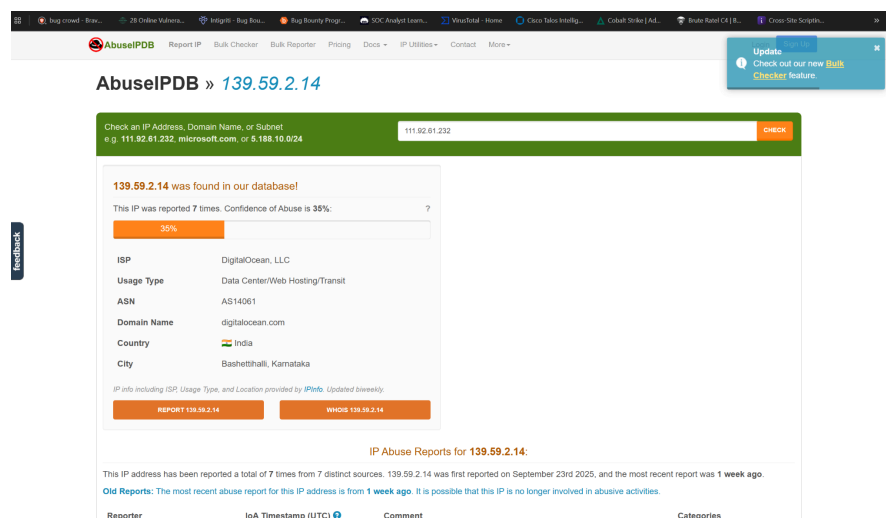
IP Geolocation

City	Báshettihalli
State	Karnataka

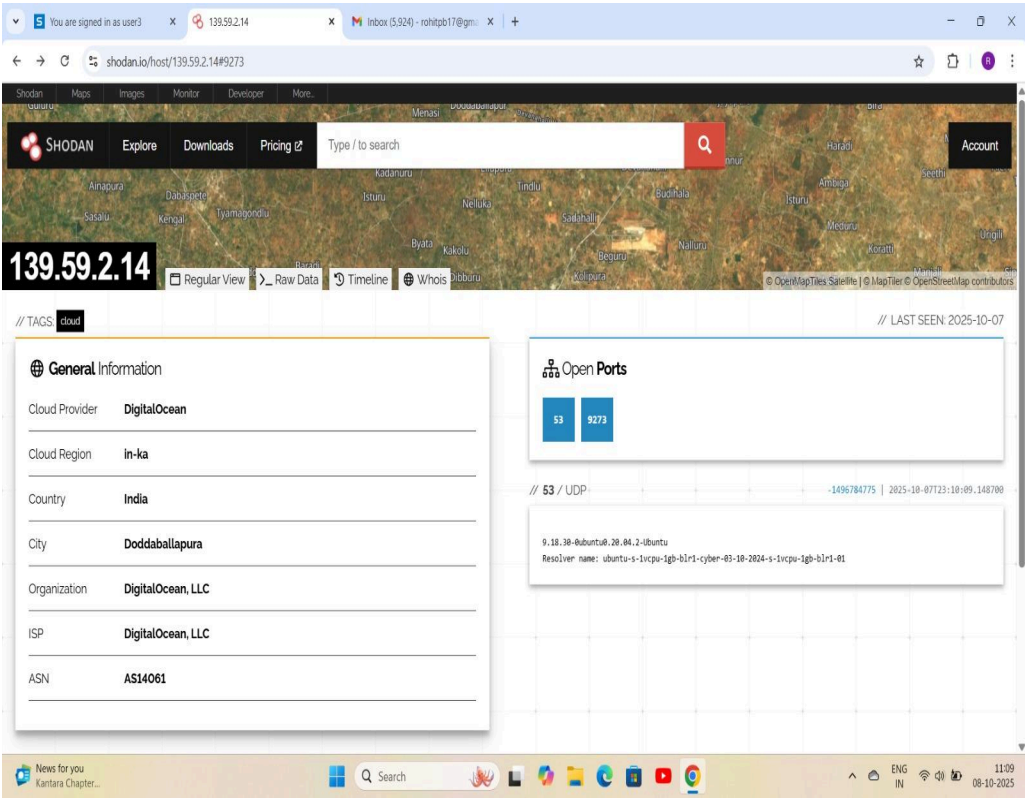
View larger map



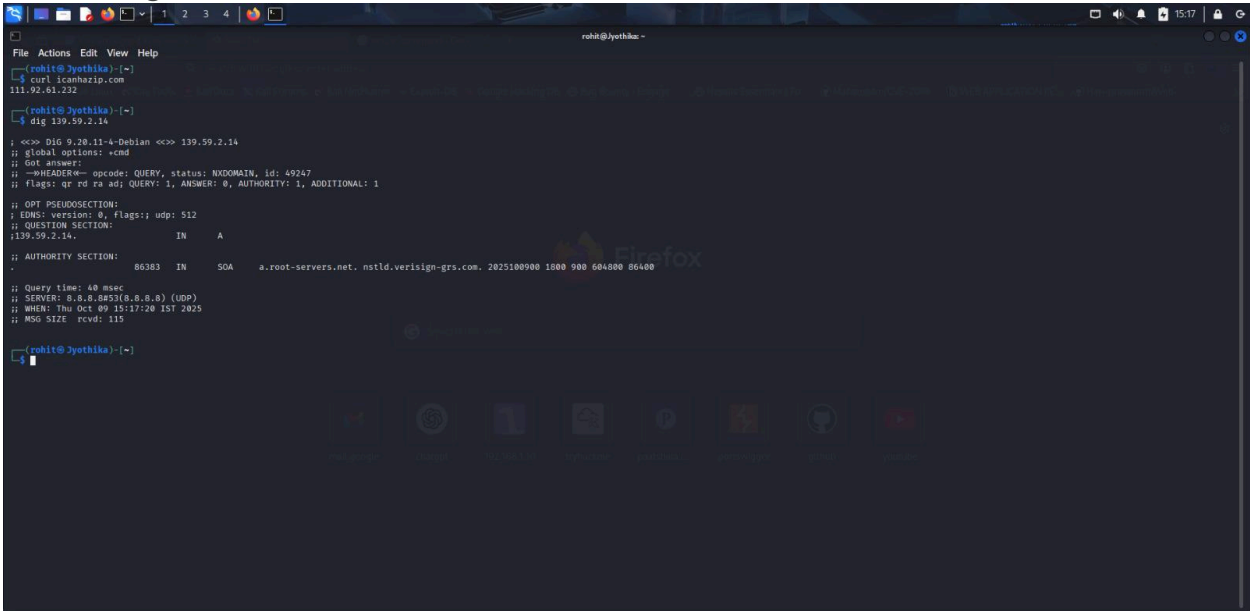
f. AbuseIPDB



g.Shodan



h. Dig



i.Censys

Kali Linux x You are signed in as user3 x 139.59.2.14 - Host Sum... x Home - Google Drive x KKEM JUN 25 CSA | Proj... x ETag explanation and ris... x (131) WhatsApp x +

https://search.censys.io/hosts/139.59.2.14/data/table#21-TCP-FTP

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB Bug Bounty - Engage... Nessus Essentials / Fo... Mahamedm/CVE-2019... WEB APPLICATION PE... Hari-prasaanth/Web...

censys 139.59.2.14 Search Register Log In

services.transport_protocol	TCP	Q
services.truncated	false	Q

111/PORTMAP TCP

View Definition

Attribute	Value	
services.banner		Q
services.banner_hashes	sha256:e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855	Q
services.discovery_method	PREDICTIVE_METHOD_23	Q
services.extended_service_name	PORTMAP	Q
services.observed_at	2025-10-06T20:35:33.662376682Z	
services.parsed.portmap.portmap_entries_v2	None	Q
services.parsed.portmap.portmap_entries_v3.shortname	pmapprog portmap rpcbind	Q
services.parsed.portmap.portmap_entries_v3.desc	portmapper	Q
services.parsed.portmap.portmap_entries_v3.version	4	Q
services.parsed.portmap.portmap_entries_v3.network_id	tcp6	Q
services.parsed.portmap.portmap_entries_v3.universal_address	::0.111	Q
services.parsed.portmap.portmap_entries_v3.owner	superuser	Q
services.parsed.portmap.portmap_entries_v3.shortname	pmapprog portmap rpcbind	Q
services.parsed.portmap.portmap_entries_v3.desc	portmapper	Q
services.parsed.portmap.portmap_entries_v3.version	3	Q
services.parsed.portmap.portmap_entries_v3.network_id	tcp6	Q
services.parsed.portmap.portmap_entries_v3.universal_address	::0.111	Q

Kali Linux x You are signed in as user3 x 139.59.2.14 - Host Sum... x Home - Google Drive x KKEM JUN 25 CSA | Proj... x ETag explanation and ris... x (130) WhatsApp x +

https://search.censys.io/hosts/139.59.2.14/data/table#21-TCP-FTP

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB Bug Bounty - Engage... Nessus Essentials / Fo... Mahamedm/CVE-2019... WEB APPLICATION PE... Hari-prasaanth/Web...

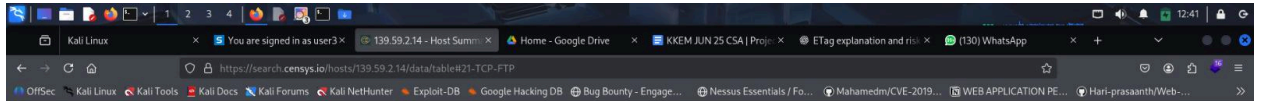
censys 139.59.2.14 Search Register Log In

services.truncated	false	Q
--------------------	-------	---

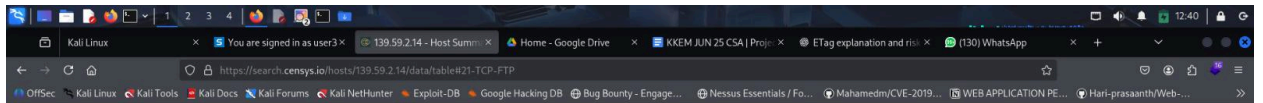
25/SMTP TCP

View Definition

Attribute	Value	
services.banner	220 ubuntu-s-1vcpu-1gb-blr1-01 ESMTP Postfix (Ubuntu)\n	Q
services.banner_hashes	sha256:ff371964c82da0373f924be3e6ab39dafa6653dad32fd0c0fd311b51f5307	Q
services.banner_hex	323230207562756e74752031732031766370752d3167622d62c72312d30312045534d545	Q
	020506f737466697820285562756e74752900da	Q
services.certificate	2e5f3f39b530559a6a3f8f8b5886def657380dd921b8c3f8eb5fc120da096c8b	Q
services.discovery_method	IPV4_WALK_FULL_PRIORITY_1	Q
services.extended_service_name	SMTP-STARTTLS	Q
services.labels	email	Q
services.observed_at	2025-10-07T02:16:49.15973221Z	
services.perspective_id	PERSPECTIVE_UNKNOWN	Q
services.port	25	Q
services.service_name	SMTP	Q
services.smtp_banner	220 ubuntu-s-1vcpu-1gb-blr1-01 ESMTP Postfix (Ubuntu)\n	Q
services.smtp_ehlo	250 ubuntu-s-1vcpu-1gb-blr1-01\n250 PIPELINING\n250 SIZE 1024000\n250 VRFY\n250 ETRN\n250 STARTTLS\n250 ENHANCEDSTATUSCODES\n250 8BITMIME\n250 DSN\n250 SMTPUTF8\n250 CHUNKING\n	Q
services.smtp_start_tls	220 2.0.0 Ready to start TLS\n	Q
services.software.uniform_resource_identifier	cpe:2.3:a:postfix:postfix:*****	Q



22/SSH TCP	
Attribute	Value
services.truncated	false
services.banner	SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.13
services.banner_hashes	sha256:16d1257c93230a1e3f853e8e220b480528f12eada8a2fa4dd5c6c968b5db97a
services.banner_hex	5353482d322e302d4470656e5353485f382e327031205562756e74752d302e3133
services.discovery_method	IPV4_WALK_FULL_PRIORITY_1
services.extended_service_name	SSH
services.labels	remote-access
services.observed_at	2025-10-07T04:59:19.193932865Z
services.perspective_id	PERSPECTIVE_UNKNOWN
services.port	22
services.service_name	SSH
services.software.product	openssh
services.software.other.comment	Ubuntu-4ubuntu0.13
services.software.source	OSL_APPLICATION_LAYER
services.software.uniform_resource_identifier	cpe:2.3:o:canonical:ubuntu_linux:20.04:*:*:*:*
services.software.part	o
services.software.vendor	Ubuntu
services.software.product	Linux



21/FTP TCP	
Attribute	Value
services.banner	220 ubuntu-s-1vcpu-1gb-blr1-cyber-03-10-2024-s-1vcpu-1gb-blr1-01 FTP server (Version 6.4/Ubuntu/Linux-ftpd-0.17) ready.\n
services.banner_hashes	sha256:c9d7f0366801a13a516b0ec3fda0f1380a5cb614ca14160a8b17e7aaf2d075e
services.banner_hex	3232020756e74752d302d4470656e5353485f382e327031205562756e74752d302e3133
services.discovery_method	IPV4_WALK_FULL_PRIORITY_1
services.extended_service_name	FTP
services.ftp.banner	220 ubuntu-s-1vcpu-1gb-blr1-cyber-03-10-2024-s-1vcpu-1gb-blr1-01 FTP server (Version 6.4/Ubuntu/Linux-ftpd-0.17) ready.\n
services.ftp.auth_tls_response	500 AUTH TLS: command not understood.\n
services.ftp.auth_ssl_response	500 AUTH SSL: command not understood.\n
services.ftp.status_code	220
services.ftp.status_meaning	Service ready for new user.
services.ftp.implicit_tls	false
services.labels	file-sharing
services.observed_at	2025-10-06T13:01:35.177536229Z
services.perspective_id	PERSPECTIVE_UNKNOWN

services.transport_protocol

UDP

services.truncated

false

80/HTTP

Attribute

Value

services.banner

```
HTTP/1.1 200 OK/vuDate: <REDACTED>/vvnServer: Apache/2.4.41 (Ubuntu)/vvnLast-Mod
ified: Thu, 14 Jul 2022 18:22:58 GMT/vvnEtag: "2a6-5e3c7f0be936f-gzip"/vvnAccept-Ran
ges: bytes/vvnVary: Accept-Encoding/vvnContent-Encoding: gzip/vvnContent-Length: 318
/vvnContent-Type: text/html/vn
```

services.banner_hashes

```
sha256:56c21b45441249bdc38cf4fc48512863e20923a9aee08c06a1338ab820a771ed
```

services.banner_hex

```
485454502f312e312022203020414b0bd0a446174653a20203c52454441435445443e0d0a
536572766572a204170616b68652f322e324e3a4312028562756e7475290d0a4c641737
42a4d6f4669669e5649a205468752c203134204a4756c2032032031383a32323a35
382474454b0bd0a563461673a20222616136203256538c3374664a2656539336626e7746
970220b0a4153461673a2022561673a20222616136203256538c3374667200a0a64172793a2041
6363
6570742d4265636f64696e6e70d0a436fe746556e742d456b36fe4696e673a2067746970
d0a436fe746556e742d464566e774683a2033313380d0a436fe74656e742d54797065
3a2074657f742f68746d6c0d0a
```

services.discovery_method

IPV4_WALK_FULL_PRIORITY_1

services.extended_service_name

HTTP

services.http.request_method

GET

services.http.request_uri

/139.59.2.14/

services.http.request.headers.User_Agent

Mozilla/5.0 (compatible; CensysInspect/1.1, +https://about.censys.io/)

services.http.request.headers.Accept

/*/*

services.http.response.protocol

HTTP/1.1

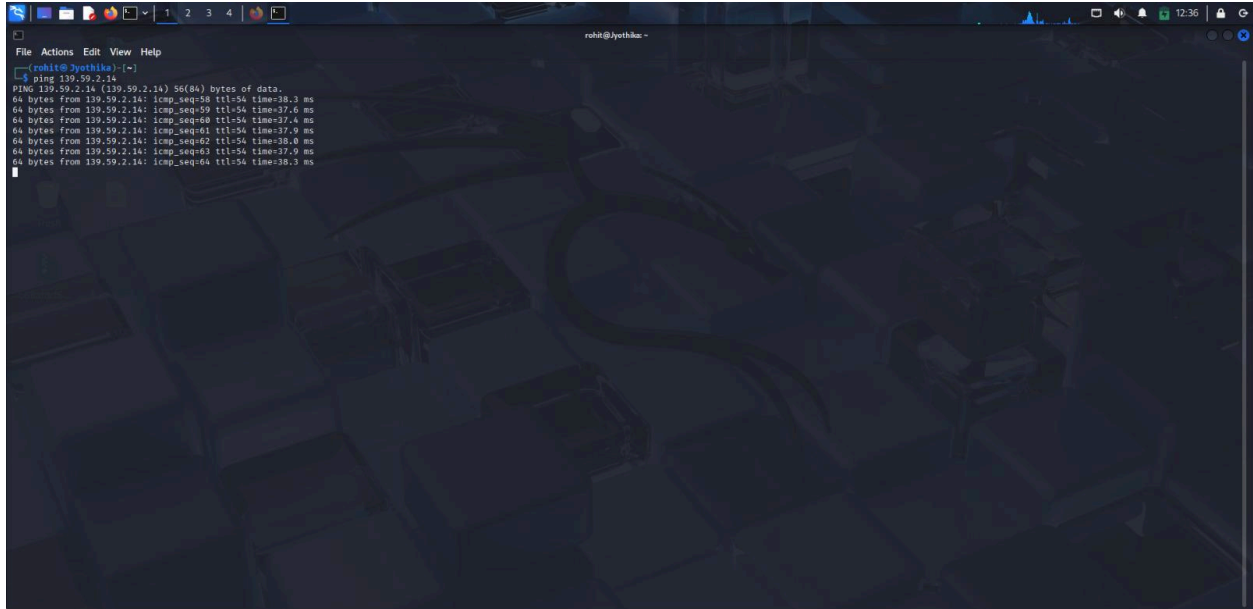
censys
🔍 Hosts ▾ 🏠 🌐 139.59.2.14
✕ 🔍 Search
[Register](#)
[Log In](#)

111/PORTMAP UDP View Definition

Attribute	Value	
services.banner		🔍
services.banner_hashes	sha256:x3B0c4D298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852db55	🔍
services.discovery_method	IPv4_WALK_FULL_PRIORITY_1	🔍
services.extended_service_name	PORTMAP	🔍
services.observed_at	2025-10-06T17:56:59.798034233Z	
services.parsed_portmap.portmap_entries_v2	None	🔍
services.parsed_portmap.portmap_entries_v3.shorthand	pmmaprog portmap rpcbind	🔍
services.parsed_portmap.portmap_entries_v3.desc	portmapper	🔍
services.parsed_portmap.portmap_entries_v3.version	4	🔍
services.parsed_portmap.portmap_entries_v3.network_id	tcp6	🔍
services.parsed_portmap.portmap_entries_v3.universal_address	:::0.111	🔍
services.parsed_portmap.portmap_entries_v3.owner	superuser	🔍
services.parsed_portmap.portmap_entries_v3.shorthand	pmmaprog portmap rpcbind	🔍
services.parsed_portmap.portmap_entries_v3.desc	portmapper	🔍
services.parsed_portmap.portmap_entries_v3.version	3	🔍
services.parsed_portmap.portmap_entries_v3.network_id	tcp6	🔍
services.parsed_portmap.portmap_entries_v3.universal_address	:::0.111	🔍
services.parsed_portmap.portmap_entries_v2.owner	superuser	🔍
services.parsed_portmap.portmap_entries_v3.shorthand	pmmaprog portmap rpcbind	🔍

2. Active Reconnaissance

a.Ping



```
rohith@jyethika:~$ ping 139.59.2.14
PING 139.59.2.14 (139.59.2.14) 56(84) bytes of data:
64 bytes from 139.59.2.14: icmp_seq=58 ttl=54 time=38.3 ms
64 bytes from 139.59.2.14: icmp_seq=59 ttl=54 time=37.6 ms
64 bytes from 139.59.2.14: icmp_seq=60 ttl=54 time=37.4 ms
64 bytes from 139.59.2.14: icmp_seq=61 ttl=54 time=37.9 ms
64 bytes from 139.59.2.14: icmp_seq=62 ttl=54 time=38.0 ms
64 bytes from 139.59.2.14: icmp_seq=63 ttl=54 time=37.9 ms
64 bytes from 139.59.2.14: icmp_seq=64 ttl=54 time=38.3 ms
```

b.Nmap

```
rohit@jyothika:~$ sudo nmap -A 139.59.2.14
[sudo] password for rohit:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-06 22:24 IST
Nmap scan report for 139.59.2.14
Host is up (0.056s latency).
Not shown: 987 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    filtered telnet
25/tcp    filtered smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
389/tcp   open  ldap
445/tcp   filtered microsoft-ds
2849/tcp open  nfs
7007/tcp  filtered af3-bos
Device type: general purpose|firewall
OS: Linux 4.19 - 5.15 (94%), Linux 2.6.32 or 3.10 (89%), Linux 4.0 - 4.4 (89%), IPFire 2.27 (Linux 5.15 - 6.1) (88%), Linux 4.15 (87%), Linux 5.4 (87%), Linux 2.6.32 - 2.6.35 (86%), Linux 2.6.32 - 2.6.39 (85%)
Running (NIST GUESSING): Linux 4.X|2.6.X|3.X|5.X (94%), IPFire 2.X (88%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:2.6.32 cpe:/o:linux:linux_kernel:3.10 cpe:/o:ipfire:ipfire:2.27 cpe:/o:linux:linux_kernel:5.15 cpe:/o:linux:linux_kernel:6.1
Aggressive OS guesses: Linux 4.19 - 5.15 (94%), Linux 2.6.32 (89%), Linux 2.6.32 or 3.10 (89%), Linux 4.0 - 4.4 (89%), IPFire 2.27 (Linux 5.15 - 6.1) (88%), Linux 4.15 (87%), Linux 5.4 (87%), Linux 2.6.32 - 2.6.35 (86%), Linux 2.6.32 - 2.6.39 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 18 hops
Service Info: Host: ubuntu-s-1vcpu-1gb-blr1-cyber-03-10-2024-s-1vcpu-1gb-blr1-01; OS: Linux; CPE: cpe:/o:linux:linux_kernel
TRACEROUTE (using port 143/tcp)
HOP RTT ADDRESS
1 5.40 ms 192.168.1.1
2 ...
3 5.42 ms 118.151.164.202.asianet.co.in (202.164.151.118)
4 4.37 ms 41.151.164.202.asianet.co.in (202.164.151.41)
5 4.40 ms 19.1.1.1
6 7.33 ms 194.148.164.202.asianet.co.in (202.164.148.194)
7 ...
13 58.75 ms 139.59.2.14
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (2 host up) scanned in 31.58 seconds
rohit@jyothika:~$
```

```
rohit@jyothika:~$ sudo nmap -A 139.59.2.14
[sudo] password for rohit:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-06 22:24 IST
Nmap scan report for 139.59.2.14
Host is up (0.056s latency).
Not shown: 987 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    filtered telnet
25/tcp    filtered smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
389/tcp   open  ldap
445/tcp   filtered microsoft-ds
2849/tcp open  nfs
7007/tcp  filtered af3-bos
Device type: general purpose|firewall
OS: Linux 4.19 - 5.15 (94%), Linux 2.6.32 or 3.10 (89%), Linux 4.0 - 4.4 (89%), IPFire 2.27 (Linux 5.15 - 6.1) (88%), Linux 4.15 (87%), Linux 5.4 (87%), Linux 2.6.32 - 2.6.35 (86%), Linux 2.6.32 - 2.6.39 (85%)
Running (NIST GUESSING): Linux 4.X|2.6.X|3.X|5.X (94%), IPFire 2.X (88%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:2.6.32 cpe:/o:linux:linux_kernel:3.10 cpe:/o:ipfire:ipfire:2.27 cpe:/o:linux:linux_kernel:5.15 cpe:/o:linux:linux_kernel:6.1
Aggressive OS guesses: Linux 4.19 - 5.15 (94%), Linux 2.6.32 (89%), Linux 2.6.32 or 3.10 (89%), Linux 4.0 - 4.4 (89%), IPFire 2.27 (Linux 5.15 - 6.1) (88%), Linux 4.15 (87%), Linux 5.4 (87%), Linux 2.6.32 - 2.6.35 (86%), Linux 2.6.32 - 2.6.39 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 18 hops
Service Info: Host: ubuntu-s-1vcpu-1gb-blr1-cyber-03-10-2024-s-1vcpu-1gb-blr1-01; OS: Linux; CPE: cpe:/o:linux:linux_kernel
TRACEROUTE (using port 143/tcp)
HOP RTT ADDRESS
1 5.40 ms 192.168.1.1
2 ...
3 5.42 ms 118.151.164.202.asianet.co.in (202.164.151.118)
4 4.37 ms 41.151.164.202.asianet.co.in (202.164.151.41)
5 4.40 ms 19.1.1.1
6 7.33 ms 194.148.164.202.asianet.co.in (202.164.148.194)
7 ...
13 58.75 ms 139.59.2.14
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (2 host up) scanned in 31.58 seconds
rohit@jyothika:~$
```

C.Gobuster

```
rohit@jyothika: ~  
File Actions Edit View Help  
Error: the server returns a status code that matches the provided options for non existing url. http://139.59.2.14/1f4ba31d-6da9-4210-85f5-e408d2ae917e => 200 (Length: 716). To continue please exclude the status code or the length  
rohit@jyothika: ~  
$ gobuster dir -u http://139.59.2.14/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
Gobuster v3.6  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
[+] Url: http://139.59.2.14/  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.6  
[+] Timeout: 10s  
Starting gobuster in directory enumeration mode  
/javascript (Status: 301) [Size: 315] => http://139.59.2.14/javascript/  
/phpmyadmin (Status: 301) [Size: 315] => http://139.59.2.14/phpmyadmin/  
/server-status (Status: 403) [Size: 276]  
Progress: 220560 / 220561 (100.00%)  
Finished  
rohit@jyothika: ~  
$ dirb http://139.59.2.14/ /usr/share/wordlists/dirb/common.txt  
DIRB v2.22  
By The Dark Raver  
START TIME: Wed Oct 8 12:06:46 2025  
URL BASE: http://139.59.2.14/  
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt  
GENERATED WORDS: 4612  
--- Scanning URL: http://139.59.2.14/ ---  
+ http://139.59.2.14/index.html (CODE:200|SIZE:10918)  
=> DIRECTORY: http://139.59.2.14/javascript/  
=> DIRECTORY: http://139.59.2.14/phpmyadmin/  
+ http://139.59.2.14/server-status (CODE:403|SIZE:276)  
--- Entering directory: http://139.59.2.14/javascript/ ---  
=> DIRECTORY: http://139.59.2.14/javascript/jquery/
```

d.Curl

```
rohit@jyothika: ~  
File Actions Edit View Help  
$ curl -s http://139.59.2.14  
HTTP/1.1 200 OK  
Date: Wed, 08 Oct 2025 18:37:12 GMT  
Server: Apache/2.4.41 (Ubuntu)  
Last-Modified: Thu, 16 Jul 2022 18:22:58 GMT  
ETag: "4aee3dc7f9e9b1f"  
Accept-Ranges: bytes  
Content-Length: 10918  
Vary: Accept-Encoding  
Keep-Alive: timeout=5, max=100  
Content-Type: text/html  
Via: HTTP/1.1 forward:http.proxy:3120  
Connection: keep-alive  
rohit@jyothika: ~  
$
```

9. References

- Apache2 Documentation
- Nmap, Gobuster manuals
- ipinfo.io, Shodan OSINT
- Server security best practices

10. Review Checklist

- Passive OSINT performed
- Port scan completed
- Directory enumeration performed
- All findings reviewed
- Recommendations included

11. Contribution

1. Team member - Rohit P.B.

Public i.p - 111.92.61.232

Tools used - Nmap ,curl , Shodan

2. Team member - Amana Fathima

Public i.p - 111.92.61.232

Tools used - whois , Ipinfo , Dig

3. Team member - Arjun. S

Public i.p - 111.92.61.232

Tools used - Gobuster , Censys , Abuseidpb

12. Conclusion

The reconnaissance phase uncovered several critical exposures on 139.59.2.14, likely stemming from test, development, or minimally maintained deployment. Even at the reconnaissance phase, these findings establish a high baseline risk and demonstrate susceptibility to automated and targeted attacks. Urgent action should be taken to restrict sensitive endpoints, enable HTTPS, and harden configurations before performing a vulnerability assessment or penetration test.

**PHASE 3 -
VULNERABILITY ASSESSMENT**

Vulnerability Assessment Report

Target IP: 139.59.2.14

Assessment Date: October 10 -12, 2025

Client/Organization: ICTAK

Assessment Team: P.B.ROHIT, AMANA FATHIMA, ARJUN SUNIL

Scope: Public web server (Apache/2.4.41 on Ubuntu), exposed phpMyAdmin, standard endpoints

1. Executive Summary

A comprehensive vulnerability assessment of the web server at **139.59.2.14** reveals serious risks posed by a large number of critical, high, medium, and low severity issues. These include remotely exploitable vulnerabilities in Apache, PHP, OpenSSL, and the phpMyAdmin application. Immediate action is recommended to prevent business impact, data compromise, or platform takeover.

2. Methodology

- **Frameworks Applied:**

- OWASP Top 10 (Web Application Risks)
- NIST SP 800-115 (Technical Guide for Information Security Testing)
- Industry best practices for periodic and event-based assessments.

- **Testing Tools and Procedures:**

- Automated scanning: Nessus, Nikto, Gobuster, Burp Suite, Openvas , Nuclei, custom scripts.
- Manual validation: Browser/cURL probes, header/response analysis, CVE mapping.
- Vulnerabilities classified by risk (Critical, High, Medium, Low) using CVSS scores, exploitability, and environmental impact.

3. Vulnerability Summary Report

Severity	Number	Key Issues
Critical	32	Apache RCE, Auth bypass, PHP/OpenSSL RCE, phpMyAdmin XSS
High	35	DoS, SSL/TLS, Expiry, Information leak
Medium	35	Outdated protocol/methods, missing headers
Low	5	Weak DH, unused/test endpoints

4. Detailed Vulnerability Registry

Severity	Vulnerability Title	CVE/Reference(s)	Location/Evidence	Remediation	Status
Critical	Apache Path Traversal/RCE	CVE-2021-41773, CVE-2021-42013	Apache/2.4.41, /, logs	Patch to Apache 2.4.60+; harden config	Open
Critical	Request Smuggling (mod_proxy)	CVE-2023-25690	mod_proxy, web logs	Patch & reconfigure mod_proxy/module	Open
Critical	PHP-FPM Remote Code Execution	CVE-2019-11043	php, Apache error log	Upgrade PHP to latest supported version	Open
Critical	phpMyAdmin XSS/Session Hijack	CVE-2025-24530	/phpmyadmin	Update phpMyAdmin $\geq 5.2.2$; restrict IP access	Open
Critical	SSRF / Buffer Overflow in mod_http2	CVE-2022-36760, CVE-2020-1934	mod_http2, server logs	Patch modules; review configurations	Open
Critical	SWEET32 – Weak Cipher Suite	CVE-2016-2183	TLS config, Nessus	Remove/disable 3DES, RC4 ciphers	Open
High	Expired/Untrusted SSL Certificate	Nessus Plugin 51192	SSL scan, browser warning	Obtain and install trusted/up-to-date cert	Open
High	Info Disclosure via Headers/Banners	-	HTTP responses, Nikto scan	Sanitize server/version headers	Open
High	Buffer Overflow in mod_proxy	CVE-2020-1934	mod_proxy error logs	Patch/reconfigure module	Open
High	TRACE/TRACK HTTP Methods Enabled	Nikto, RFC2616	HTTP response	Disable TRACE/TRACK methods in Apache conf	Open

Medium	Missing Security Headers	Nikto OWASP2017	HTTP response headers	Add X-Frame-Options, CSP, etc.	Open
Medium	TLS 1.0/1.1 Protocols Enabled	SSL Labs/Qualys	SSL/TLS negotiation	Allow TLS 1.2+ only	Open
Medium	Deprecated Libraries in Use	Nmap/Nessus	Package list, scan output	Upgrade outdated libraries	Open
Low	Unused /test or /manual Endpoints Found	Gobuster, Nikto	/test, /manual	Remove/disable unused endpoints	Open
Low	1024-bit Diffie-Hellman Group	SSL Labs, Nessus 10180	TLS handshake	Use $\geq$ 2048-bit for DHE/ECDHE	Open

5. Risk Assessment

This assessment uncovered a spectrum of vulnerabilities across the target machine's web stack:

- **Remote Code Execution & Privilege Escalation:**

Multiple critical flaws (Apache, PHP-FPM, mod_proxy) enable attackers to execute arbitrary commands with system privileges, potentially resulting in server takeover, malware deployment, and total compromise of system assets.

- **Authentication Bypass & Session Hijacking:**

Exploits in authentication mechanisms and exposed admin panels (phpMyAdmin) allow attackers to circumvent login controls, hijack sessions, and access restricted functionality or sensitive databases

- **Denial of Service Attacks:**

Buffer overflows, SSRF, and module-specific flaws (mod_http2, mod_proxy, etc.) can be exploited to crash or disrupt services, resulting in loss of business continuity and user access

- **Sensitive Data Exposure:**

Information leakage through exposed server headers, outdated SSL/TLS protocols, and weak cryptography could aid attackers in targeting specific weaknesses, intercepting data in transit, or performing further reconnaissance.

- **Regulatory & Reputational Impact:**

Use of expired SSL certificates, insufficient encryption, and unpatched vulnerable services could violate compliance mandates (e.g., GDPR, PCI DSS) leading to fines and damaging customer trust.

Risk Severity:

- Probability of exploitation is high due to the age and public exposure of components.
- The business impact of a successful attack ranges from data theft and service disruption to regulatory fines and irreparable reputational harm.
- Multiple vulnerabilities are chainable—increasing attacker success rates.

6. Recommendations

Immediate Actions (Critical Response):

- **Patch all Critical Software:**
Upgrade Apache, PHP, OpenSSL, and phpMyAdmin immediately to close known RCE, SSRF, and SQLi/XSS gaps.
- **Restrict Administrative Access:**
Limit phpMyAdmin and other sensitive endpoints to trusted IPs or internal networks; consider using VPN and strong authentication.
- **Harden SSL/TLS Configurations:**
Disable weak protocols (TLS 1.0/1.1), remove support for weak ciphers (RC4, 3DES), and update digital certificates.
- **Implement Security Headers:**
Enforce X-Frame-Options, Content-Security-Policy, HSTS, X-XSS-Protection, etc. in server responses.
- **Remove Unused Endpoints & Files:**
Delete test/admin/dev directories from production systems and remove verbose server banners.

7. Appendices

1. gobuster

```
rohit@jyothika: ~  
File Actions Edit View Help  
Error: the server returns a status code that matches the provided options for non existing urls. http://139.59.2.14/1f4ba31d-6da9-4210-85f5-e408d2ae917e => 200 (Length: 716). To continue please exclude the status code or the length  
rohit@jyothika:~  
$ gobuster dir -u http://139.59.2.14/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
Gobuster v3.6  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
[+] Url: http://139.59.2.14/  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.6  
[+] Timeout: 10s  
Starting gobuster in directory enumeration mode  
/javascript (Status: 301) [Size: 315] -> http://139.59.2.14/javascript/  
/phpmyadmin (Status: 301) [Size: 315] -> http://139.59.2.14/phpmyadmin/  
/server-status (Status: 403) [Size: 276]  
Progress: 220560 / 220561 (100.00%)  
Finished  
rohit@jyothika:~  
$ dirb http://139.59.2.14/ /usr/share/wordlists/dirb/common.txt  
DIRB v2.22  
By The Dark Raver  
START TIME: Wed Oct 8 12:08:46 2025  
URL_BASE: http://139.59.2.14/  
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt  
GENERATED WORDS: 4612  
--- Scanning URL: http://139.59.2.14/ ---  
+ http://139.59.2.14/index.html (CODE:200|SIZE:18918)  
=> DIRECTORY: http://139.59.2.14/javascript/  
=> DIRECTORY: http://139.59.2.14/phpmyadmin/  
+ http://139.59.2.14/server-status (CODE:403|SIZE:276)  
--- Entering directory: http://139.59.2.14/javascript/ ---  
=> DIRECTORY: http://139.59.2.14/javascript/jquery/
```

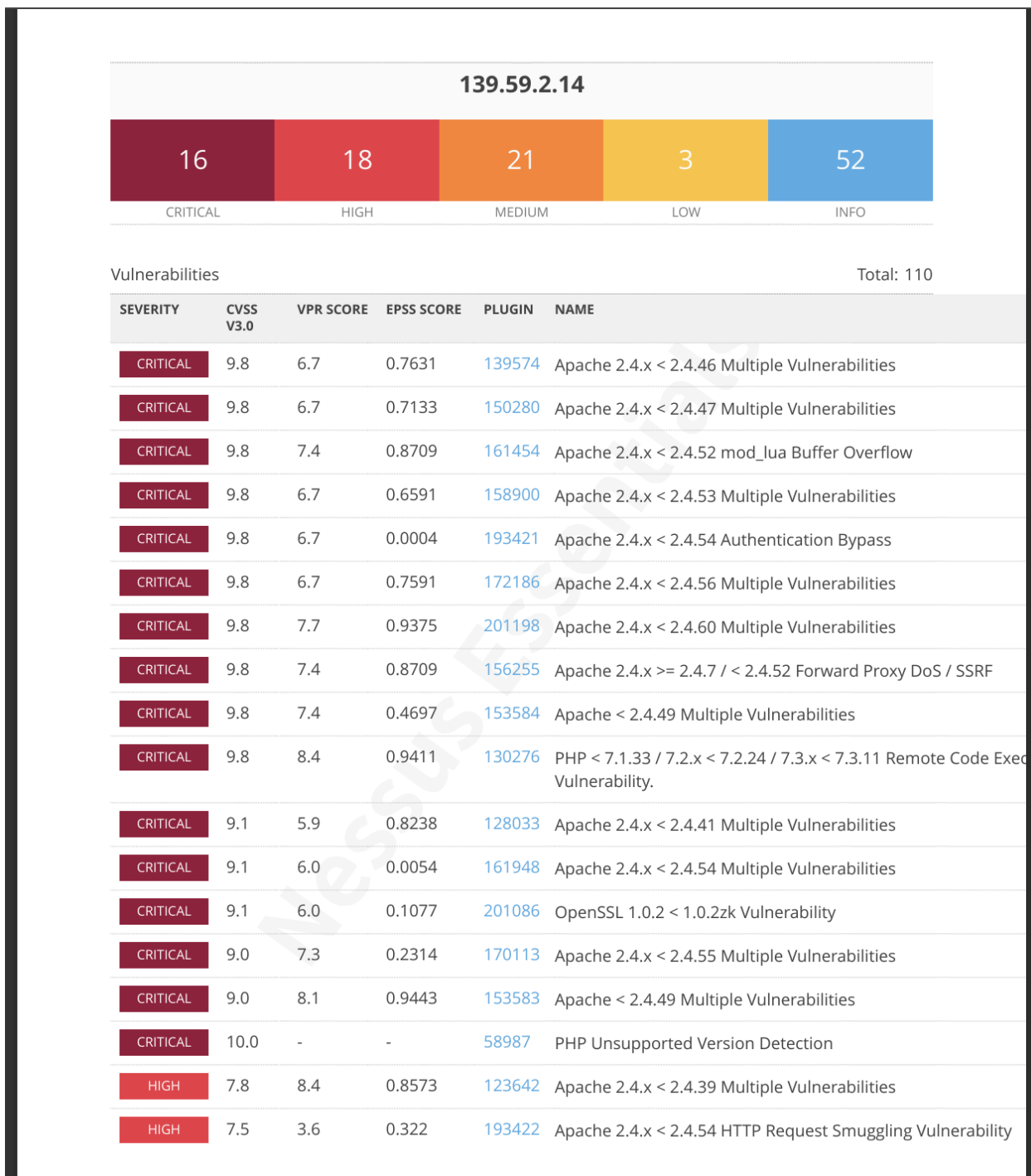
2. nikto

```
rohit@jyothika: ~  
File Actions Edit View Help  
rohit@jyothika:~  
$ nikto -h 139.59.2.14  
Nikto v2.5.0  
- Target IP: 139.59.2.14  
- Target Hostname: 139.59.2.14  
- Target Port: 80  
- Start Time: 2025-10-11 10:01:32 (GMT+5.5)  
+ Server: Apache/2.4.41 (Ubuntu)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis-sing-content-type-header/  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ Apache/2.4.41 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.  
+ /: Server may leak inodes via ETags, header found with file /, inode: 2aa6, size: 5e3c7fde936f, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST  
+ /phpmyadmin/changelog.php: Cookie goto created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies  
+ /phpmyadmin/changelog.php: Cookie back created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies  
+ /phpmyadmin/changelog.php: Uncommon header "x-ob_mode" found, with contents: 1.  
+ /phpmyadmin/: phpMyAdmin directory found.  
+ #102 requests: 0 error(s) and 9 item(s) reported on remote host  
+ End Time: 2025-10-11 10:09:13 (GMT+5.5) (461 seconds)  
+ 1 host(s) tested  
rohit@jyothika:~  
$
```

3. Openvas & nuclei

[illegible]

4 . Nessus



HIGH	7.5	3.6	0.1508	193423	Apache 2.4.x < 2.4.54 Multiple Vulnerabilities
HIGH	7.5	3.6	0.0139	193424	Apache 2.4.x < 2.4.54 Multiple Vulnerabilities (mod_lua)
HIGH	7.5	4.4	0.569	183391	Apache 2.4.x < 2.4.58 Multiple Vulnerabilities
HIGH	7.5	4.4	0.0035	193419	Apache 2.4.x < 2.4.58 Out-of-Bounds Read (CVE-2023-31122)
HIGH	7.5	4.4	0.8885	192923	Apache 2.4.x < 2.4.59 Multiple Vulnerabilities
HIGH	7.5	6.0	0.0004	241984	Apache 2.4.x < 2.4.64 Multiple Vulnerabilities
HIGH	7.5	4.4	0.0054	153585	Apache >= 2.4.17 < 2.4.49 mod_http2
HIGH	7.5	3.6	0.0388	153586	Apache >= 2.4.30 < 2.4.49 mod_proxy_uwsgi
HIGH	7.5	4.4	0.104	158973	OpenSSL 1.0.2 < 1.0.2zd Vulnerability
HIGH	7.5	5.1	0.0002	266318	OpenSSL 1.0.2 < 1.0.2zm Vulnerability
HIGH	7.5	-	-	142591	PHP < 7.3.24 Multiple Vulnerabilities
HIGH	7.5	6.1	0.4002	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
HIGH	7.4	6.0	0.0084	152780	OpenSSL 1.0.2 < 1.0.2za Vulnerability
HIGH	7.4	6.0	0.9005	171080	OpenSSL 1.0.2 < 1.0.2zg Multiple Vulnerabilities
HIGH	7.3	6.7	0.4634	160480	OpenSSL 1.0.2 < 1.0.2ze Vulnerability
HIGH	7.3	7.4	0.2523	162419	OpenSSL 1.0.2 < 1.0.2zf Vulnerability
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	57582	SSL Self-Signed Certificate
MEDIUM	6.5	-	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	-	157288	TLS Version 1.1 Deprecated Protocol
MEDIUM	6.1	3.0	0.4187	135290	Apache 2.4.x < 2.4.42 Multiple Vulnerabilities
MEDIUM	5.9	4.4	0.0599	122504	OpenSSL 1.0.2 < 1.0.2r Vulnerability
MEDIUM	5.9	5.1	0.0027	144053	OpenSSL 1.0.2 < 1.0.2x Vulnerability
MEDIUM	5.9	4.4	0.0022	200206	OpenSSL 1.0.2 < 1.0.2zc Vulnerability
MEDIUM	5.9	4.4	0.0022	157231	OpenSSL 1.0.2 < 1.0.2zc-dev Vulnerability

MEDIUM	5.9	7.3	0.9032	65821	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
MEDIUM	5.5	4.4	0.0274	184812	OpenSSL 1.0.2 < 1.0.2zj Multiple Vulnerabilities
MEDIUM	5.3	1.4	0.0019	193420	Apache 2.4.x < 2.4.54 Out-Of-Bounds Read (CVE-2022-283
MEDIUM	5.3	4.0	0.6899	11213	HTTP TRACE / TRACK Methods Allowed
MEDIUM	5.3	2.2	0.0396	132726	OpenSSL 1.0.2 < 1.0.2u Vulnerability
MEDIUM	5.3	4.4	0.9197	173268	OpenSSL 1.0.2 < 1.0.2zh Multiple Vulnerabilities
MEDIUM	5.3	2.2	0.0081	178476	OpenSSL 1.0.2 < 1.0.2zi Multiple Vulnerabilities
MEDIUM	5.3	-	-	152853	PHP < 7.3.28 Email Header Injection
MEDIUM	5.3	-	-	15901	SSL Certificate Expiry
MEDIUM	5.3	4.2	0.0815	35291	SSL Certificate Signed Using Weak Hashing Algorithm
MEDIUM	4.7	4.4	0.0146	128115	OpenSSL 1.0.2 < 1.0.2t Multiple Vulnerabilities
MEDIUM	4.3	2.9	0.0036	209152	OpenSSL 1.0.2 < 1.0.2zl Vulnerability
LOW	3.7	2.2	0.0074	146374	OpenSSL 1.0.2 < 1.0.2w Vulnerability
LOW	3.7	4.4	0.006	146591	OpenSSL 1.0.2 < 1.0.2y Multiple Vulnerabilities
LOW	3.7	3.9	0.9403	83875	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Preventive & Long-term Actions:

- **Establish Patch Management Routine:**
Schedule regular updates for all software components and monitor vulnerability disclosures.
- **Continuous Monitoring & Logging:**
Deploy intrusion detection/prevention solutions and actively monitor server logs for suspicious activity.
- **Incident Response Planning:**
Develop and rehearse incident response scenarios, including containment and forensic investigation procedures.
- **Backup & Recovery Strategy:**
Regularly backup system data in secure, off-site/immutable locations, and test system recovery processes.
- **Periodic Vulnerability Assessments:**
Re-assess systems quarterly or after major changes; include both automated and manual testing.

Regulatory Compliance & Awareness:

- Ensure all changes and controls satisfy industry standards (e.g., PCI DSS, HIPAA, GDPR).
- Train IT staff on secure configuration, patching, and the risks posed by vulnerability exploitation.
- Document all remedial and preventive action for audit and ongoing risk governance.

These actions will address all identified threats, mitigate current risks, and foster a resilient, compliant IT environment for the organization.

8. Contribution

1. Team member - Rohit P.B.

Public i.p - 111.92.61.232 ,

Tools used - Gobuster , nikto ,Nessus

2. Team member - Amana Fathima

Public i.p - 111.92.61.232

Tools used - Openvas , nuclei , Nessus

3. Team member - Arjun. S

Public i.p - 111.92.61.232

Tools used - Gobuster , Nuclei , Nessus

9. Conclusion

The vulnerability assessment of IP **139.59.2.14** has demonstrated an urgent need for remediation due to the presence of multiple critical and high-risk security issues across its Apache web server, PHP runtime, OpenSSL implementation, and phpMyAdmin interface. The exposure of these vulnerabilities—such as remote code execution, authentication bypass, XSS, SSRF, and weak cryptographic protocols—places the server and its data at considerable risk for exploitation, loss of confidentiality, service interruption, and regulatory non-compliance.

Immediate action should focus on patching all core software components, reconfiguring and protecting sensitive endpoints, and implementing best-practice hardening and monitoring procedures in accordance with current cybersecurity standards. Ongoing vulnerability management and regular reassessment are essential to sustain a robust security posture and protect organizational assets against evolving threats.

This report serves as a comprehensive guide for technical teams and management to address current risks and to establish ongoing processes for vulnerability detection and mitigation.

10. References

1. OWASP Foundation. "OWASP Top Ten." <https://owasp.org/www-project-top-ten/>
2. NIST. "Technical Guide to Information Security Testing and Assessment (SP 800-115)." <https://csrc.nist.gov/publications/detail/sp/800-115/final>
3. EC-Council. "How to Write a Vulnerability Assessment Report." <https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/how-to-write-vulnerability-assessment-report/>
4. Apache Software Foundation. "Apache HTTP Server 2.4 Vulnerabilities." https://httpd.apache.org/security/vulnerabilities_24.html
5. Snypk. "Vulnerability report for Docker httpd:2.4.41-alpine." <https://snypk.io/test/docker/httpd:2.4.41-alpine>
6. Qualysec. "Vulnerability Assessment Reports: A Complete Guide." <https://qualysec.com/vulnerability-assessment-reports-a-complete-guide/>
7. IBM. "What Is a Vulnerability Assessment?" <https://www.ibm.com/think/topics/vulnerability-assessment>
8. Nikto Project. "Nikto Web Server Scanner." <https://github.com/sullo/nikto>
9. Indusface. "Vulnerability Assessment Checklist." <https://www.indusface.com/blog/vulnerability-assessment-checklist/>
10. Balbix. "What is a Vulnerability Assessment?" <https://www.balbix.com/insights/vulnerability-assessments-drive-enhanced-security-and-cyber-resilience/>
11. Nessus Scanning report https://drive.google.com/file/d/1VVkaTn1ZkA1qnTZbOXi_zgZzvONdPmh4/view?usp=drive_link
12. Tenable Inc. "Nessus User Guide" <https://docs.tenable.com/nessus.htm>

Phase 4 -
PENETRATION TESTING PHASE

1. Engagement Overview

- Project Name: Penetration Testing
- Client / Organization: ICTAK
- Date of Penetration Test: 13-10-2025
- Test Team / Tester: Rohit P.B ,Amana Fathima , Arjun S
- Target Scope of Penetration Test: 139.59.85.166

2. Executive Summary

- Multiple critical web application vulnerabilities found, including:
 - Weak/default credentials on login
 - Information disclosure (sensitive files and credentials exposed)
 - Cross-Site Scripting (XSS) in comments and messages
 - SQL Injection risks in login and form inputs
 - Session management issues (predictable PHPSESSID cookies)
 - Unrestricted file uploads (possible webshell risk)
 - CSRF exposure (no anti-CSRF tokens on forms)
 - IDOR (predictable direct page references)
 - Broken authentication controls
-

3. Methodology and Exploitation Strategy

- Nmap port scanning showed open TCP port 566686
 - Web interface analyzed for input validation issues
 - Burp Suite for session manipulation and cookie interception
 - Manual inspection of upload and user/admin controls
-

4. Detailed Exploitation Scenarios

- Weak Credentials: Login as `admin/admin`
- Information Disclosure: Direct access to `/uploads`, plaintext credentials visible
- XSS: Payload `javascript:alert(1)` ; accepted and rendered in comments
- SQL Injection: Standard payloads like `OR 1=1--` not properly sanitized in fields

- Session Management: PHPSESSID not secured with flags and predictable pattern
 - File Upload: Able to upload files via image uploads, no type restriction
 - CSRF: No tokens or validation on forms
 - IDOR: Sequential IDs grant access to user comments/blogs without auth
 - Broken Authentication: Role/privilege changes accessible through direct URLs
-

5. Highest Level of Access & Business Impact

- Gained admin panel access
- Exposed user and admin credentials
- Downloaded sensitive files
- Able to manipulate user data

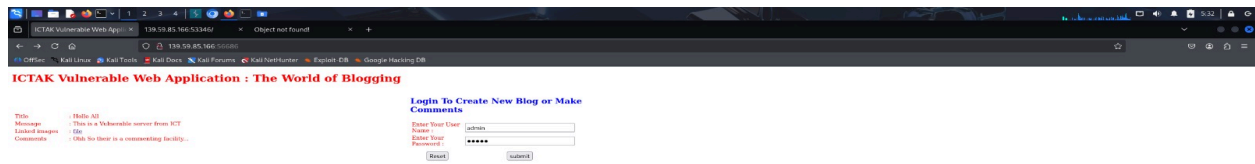
Potential impact includes data theft, service disruption, and compromise of the organization's reputation and trust.

6. Appendix

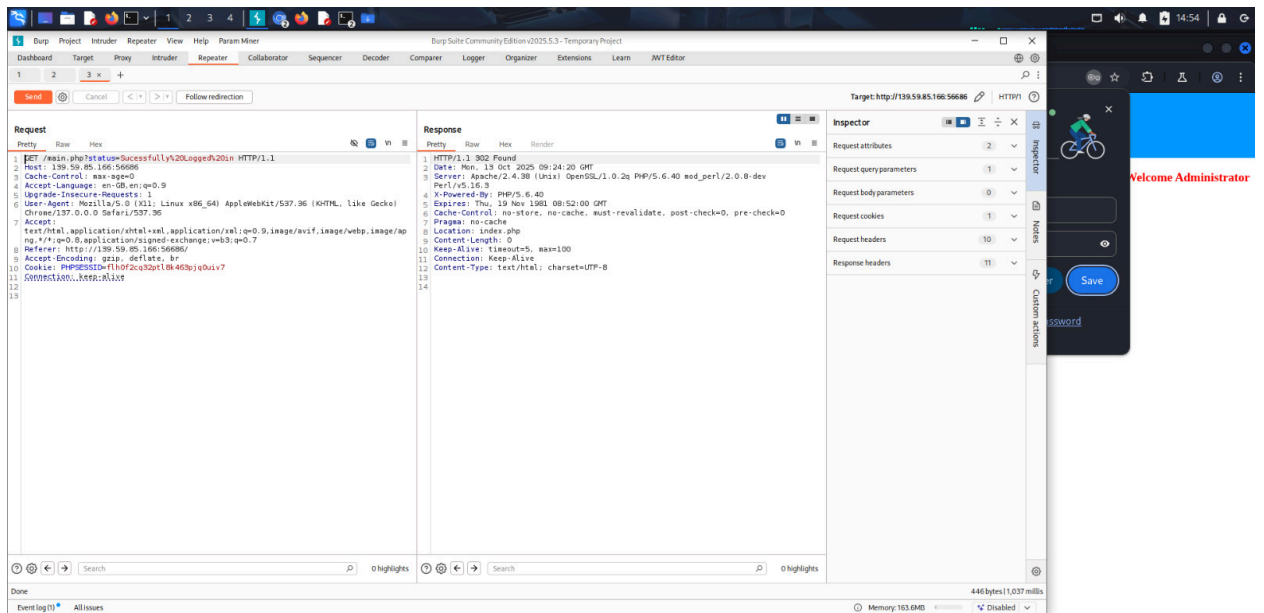
- Nmap

```
rohit@jyothika:~$ sudo nmap -v 10.10.10.10
Nmap scan report for 10.10.10.10
Host is up (0.0000ms latency).
Not shown: 9997 closed tcp ports (reset)
PORT      STATE SERVICE
5118/tcp  filtered unknown
5238/tcp  open   unknown
5444/tcp  open   unknown
5668/tcp  open   unknown
Nmap done: 1 IP address (1 host up) scanned in 5.67 seconds
```

- Loginpage



- Php session cookie tampering



Wireshark interface showing a successful login request and response. The request is a POST to /main.php?status=Successfully20. The response is a 302 Found redirecting to index.php.

Request:

```
1 POST /main.php?status=Successfully20. HTTP/1.1
2 Host: 139.59.85.166:56686
3 Cache-Control: max-age=0
4 Accept-Language: en-GB,en;q=0.9
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Referer: http://139.59.85.166:56686/
9 Accept-Encoding: gzip, deflate, br
10 Cookie: PHPSESSID=11a0f5c3q3p18.463p;q0u1v7
11 Connection: keep-alive
12
13
```

Response:

```
1 HTTP/1.1 302 Found
2 Date: Mon, 13 Oct 2025 09:24:20 GMT
3 Server: Apache/2.4.38 (Ubuntu) OpenSSL/1.0.2q PHP/5.6.40 mod_perl/2.0.8-dev Perl/5.16.3
4 X-Powered-By: PHP/5.6.40
5 Expires: Thu, 19 Nov 1969 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
7 Pragma: no-cache
8 Location: index.php
9 Content-Length: 0
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html; charset=UTF-8
13
14
```

Wireshark interface showing a successful login request and response. The response is a 302 Found redirecting to index.php. The response body contains a message: "ICTAK Vulnerable Web Application : The World of Blogging".

Request:

```
1 GET /index.php HTTP/1.1
2 Host: 139.59.85.166:56686
3 Cache-Control: max-age=0
4 Accept-Language: en-GB,en;q=0.9
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Referer: http://139.59.85.166:56686/main.php?status=Successfully20.
9 Accept-Encoding: gzip, deflate, br
10 Cookie: PHPSESSID=11a0f5c3q3p18.463p;q0u1v7
11 Connection: keep-alive
12
13
```

Response:

```
1 HTTP/1.1 302 Found
2 Date: Mon, 13 Oct 2025 09:24:20 GMT
3 Server: Apache/2.4.38 (Ubuntu) OpenSSL/1.0.2q PHP/5.6.40 mod_perl/2.0.8-dev Perl/5.16.3
4 X-Powered-By: PHP/5.6.40
5 Expires: Thu, 19 Nov 1969 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
7 Pragma: no-cache
8 Location: index.php
9 Content-Length: 0
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html; charset=UTF-8
13
14
```

Inspector:

Request attributes: 2

Request query parameters: 1

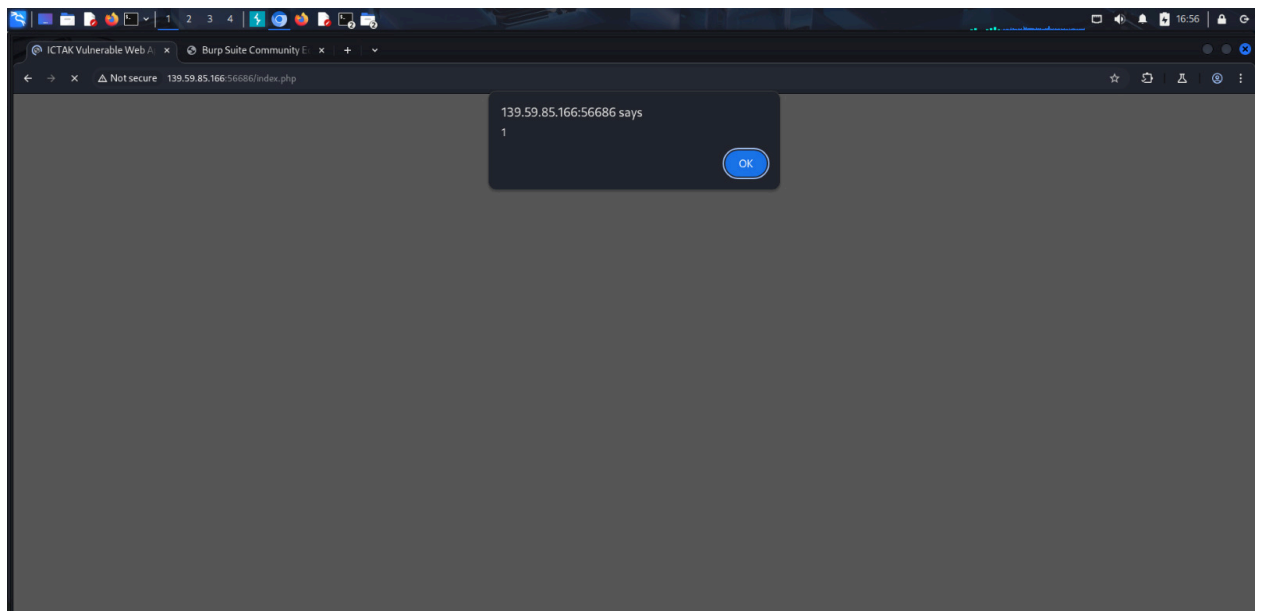
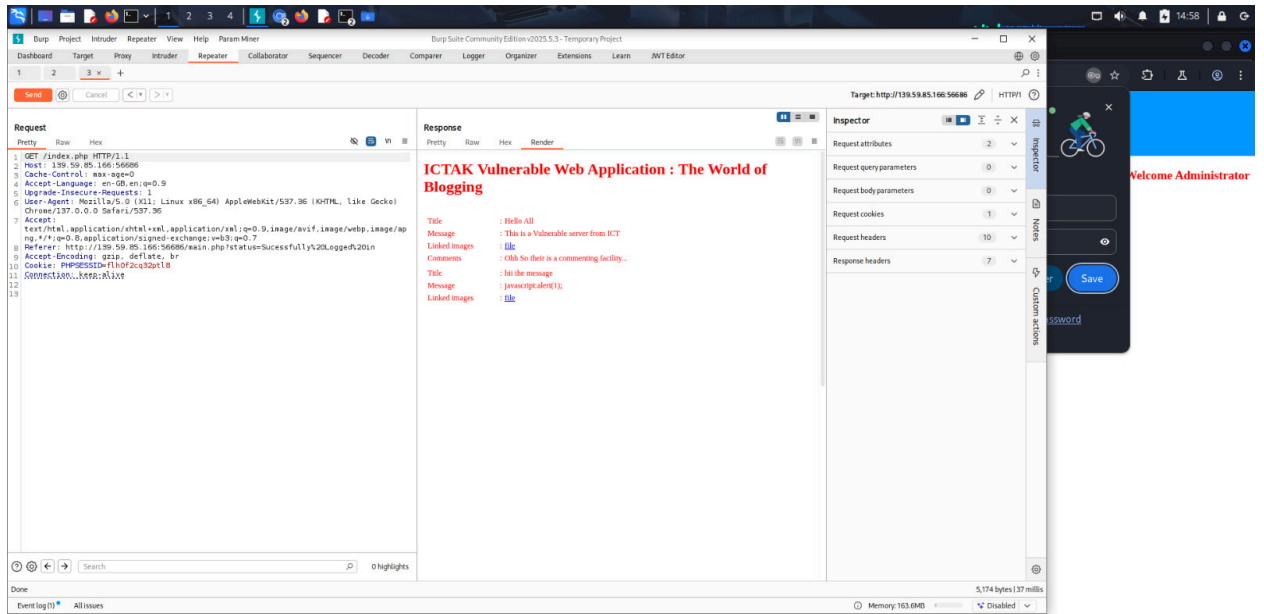
Request body parameters: 0

Request cookies: 1

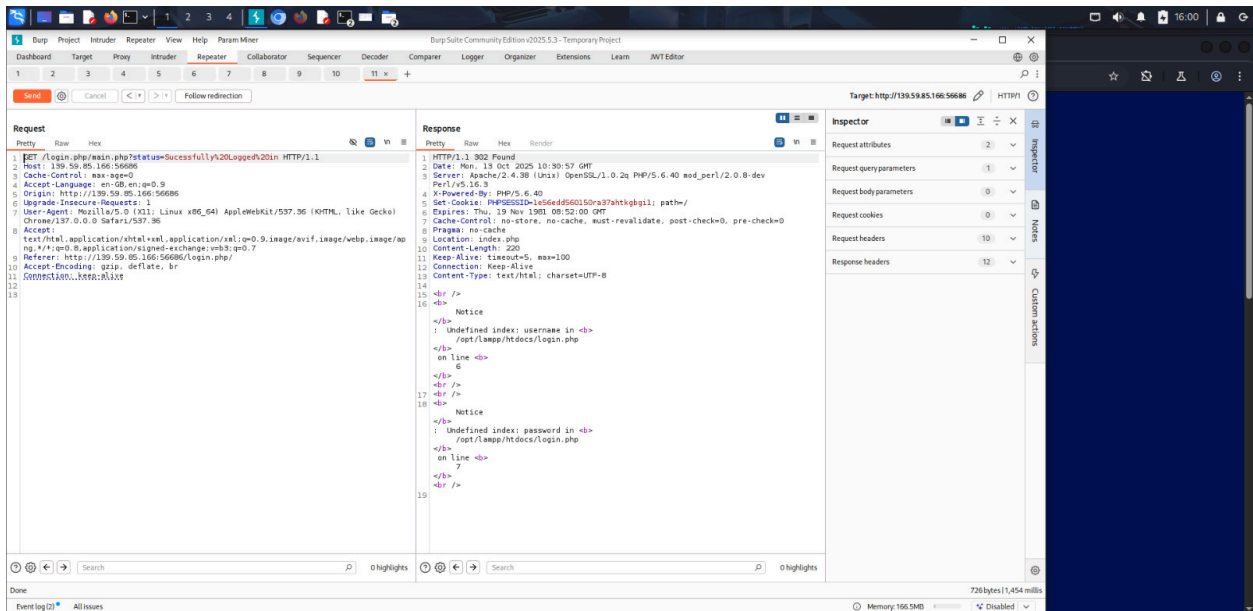
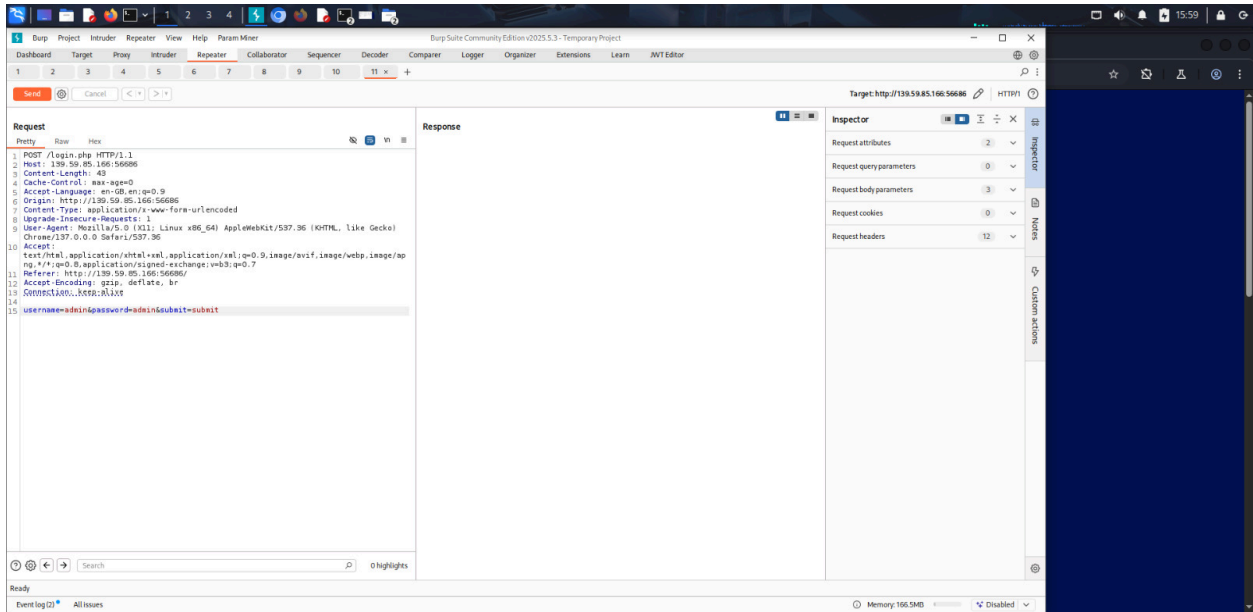
Request headers: 10

Response headers: 11

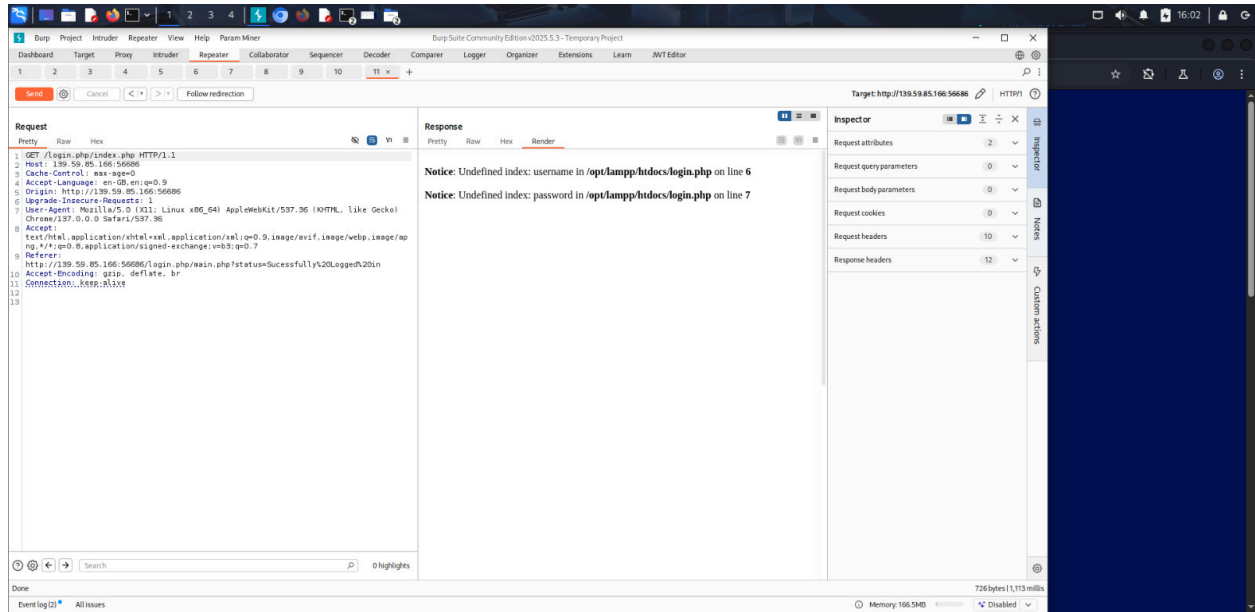
- XSS(crosssite scripting)



- Security misconfiguration



- Path traversal



7. Remediation Table

Vulnerability	Business Impact	Recommended Fix
Weak credentials	Admin access	Enforce strong password policies
Info disclosure	Data theft	Remove sensitive files; audit storage
XSS	Session hijack, deface	Input sanitization & output encoding
SQL Injection	Full DB compromise	Parameterized queries/input validation
Session risks	Account takeover	Use secure cookies & session timeout
File upload	Server compromise	Validate file types, restrict uploads

CSRF	Unauthorized actions	Implement anti-CSRF tokens
IDOR	Privacy breach	Access control & indirect references
Broken auth	Privilege escalation	Proper role checks, least privilege

General Remediation Steps:

- Apply patches and security updates to server and frameworks.
- Conduct regular vulnerability scans and code reviews.
- Provide secure coding training for developers.
- Monitor security logs and implement intrusion detection.

Priority Order:

1. Remove information disclosure & patch authentication weaknesses.
2. Fix SQL Injection, XSS, and upload vulnerabilities immediately.
3. Implement CSRF, session management, and access control improvements.
4. Retest and verify all fixes before moving to production.

8.Recommendation

1. Weak / Default Credentials

- Recommendation: Enforce strong password policies—not allowing default, dictionary, or common credentials (e.g., “admin/admin”).
- Remediation: Implement minimum complexity rules, mandatory password rotation, and lock accounts after multiple failed attempts.

2. Information Disclosure (Sensitive Files, Credentials)

- Recommendation: Strictly control access to sensitive files and do not store credentials or internal documentation in accessible locations.
- Remediation: Remove exposed files from uploads directory; audit file storage and permissions; sanitize output to avoid leaking server or credential information.

3. Cross-Site Scripting (XSS)

- Recommendation: Properly sanitize and encode all user inputs before rendering them into the UI.
- Remediation: Use frameworks or libraries that automatically escape output; implement input validation and output encoding for all fields where user data appears (comments, messages, form inputs).

4. SQL Injection

- Recommendation: Use prepared statements and parameterized queries for all database interactions.
- Remediation: Update all backend code to use parameterized queries (PDO / prepared statements in PHP); validate and sanitize all inputs against expected formats.

5. Session Management Risks

- Recommendation: Secure session cookies using `HttpOnly` and `Secure` flags; regularly rotate session IDs and invalidate upon logout.
- Remediation: Set PHP configuration for session cookies: `session.cookie_httponly = 1, session.cookie_secure = 1` (requires HTTPS). Implement session timeout and session fixation protection.

6. Unrestricted File Upload

- Recommendation: Restrict file uploads to safe types (e.g., images only); scan and validate file content/type both at client and server side.
- Remediation: Check MIME type and file extension; block executable/script uploads. Store files outside web root or with randomized names.

7. CSRF (Cross-Site Request Forgery)

- Recommendation: Implement CSRF tokens in all forms that change state (comments, posts, passwords, user management).
- Remediation: Use a token generator and validator for every user form—validate the token server-side before performing changes.

8. Insecure Direct Object Reference (IDOR)

- Recommendation: Avoid sequential/predictable IDs in URLs; always check user permissions server-side before granting access.
- Remediation: Use indirect references and enforce permission checks for every object accessed through the web application.

9. Broken Authentication / Access Control

- Recommendation: Implement robust role-based access controls and privilege checks for every sensitive function.
- Remediation: Audit the backend to ensure every sensitive page/action checks the user's role/privilege; remove guest/admin toggling by URL manipulation.

10. Open Redirect (Potential) and Direct File Links

- Recommendation: Validate redirect URLs and never rely on user-controlled input for redirects. Disable direct access to uploaded files unless authenticated and authorized.
- Remediation: Implement URL validation whitelisting, restrict access to uploads via authorization checks, and audit file exposure.

9. Contribution

1. Team member - Rohit P.B.

Public i.p - 111.92.61.232 ,

Tools used - nmap , curl , Burpsuite , rpcinfo

2. Team member - Amana Fathima

Public i.p - 111.92.61.232

Tools used - Shodan, Burpsuite , gobuster , Searchsploit

3. Team member - Arjun. S

Public i.p - 111.92.61.232

Tools used - Browser , nikto , Hydra ,burpsuite

10. Conclusion

The penetration test conducted on ICTAK's "World of Blogging" web application revealed a series of critical vulnerabilities that, if exploited, could result in severe business, reputational, and data security ramifications. Our test team was able to gain unauthorized administrative access, leverage weak default credentials, exploit multiple flaws to access sensitive files and user data, and manipulate application functionality far beyond expected authorization boundaries.

The application—by design or oversight—exposed sensitive credentials and documents, suffered from poor input validation, and did not enforce standard web security best practices. Attackers may readily exploit XSS or SQL injection vulnerabilities to steal user sessions, compromise database integrity, or deface the site, potentially using unrestricted file uploads to gain persistent access via web shells. CSRF flaws permit unauthorized transactions, while insecure direct object references (IDOR) expose user records to illegitimate access. Weak session management further puts user accounts at risk of hijacking, and broken access controls undermine data separation.

The business impact of these vulnerabilities is substantial:

- **Data Breach Risk:** Exposure of personal information, credentials, and organization-specific data could lead to significant regulatory and reputational consequences.
- **Service Suspension and Defacement:** Attackers can disrupt or deface the web service, impacting user trust and operational continuity.
- **Financial and Legal Liability:** Compromised user accounts, data theft, and potential malware propagation open the organization to user claims, regulatory fines, and mandatory reporting.
- **Reputation Damage:** Public exploit of these weaknesses can diminish stakeholder confidence and damage the brand irreparably.

Remediation is critical and urgent. Immediate steps should be taken to address every identified vulnerability—enforcing strong authentication, removing exposed data, validating all user inputs, and implementing industry-standard security controls on session management, file handling, and application access. Secure coding practices and regular vulnerability assessments must be established as a baseline for ongoing security assurance.

Next Steps:

- Apply all recommended fixes promptly.
- Engage an independent security review after remediation.
- Train development and operational teams in secure web application practices.
- Schedule periodic retesting and security audits.

Executing these recommendations will greatly enhance the resilience of the ICTAK blogging application, ensuring organizational data, user privacy, and business reputation are protected against evolving security threats